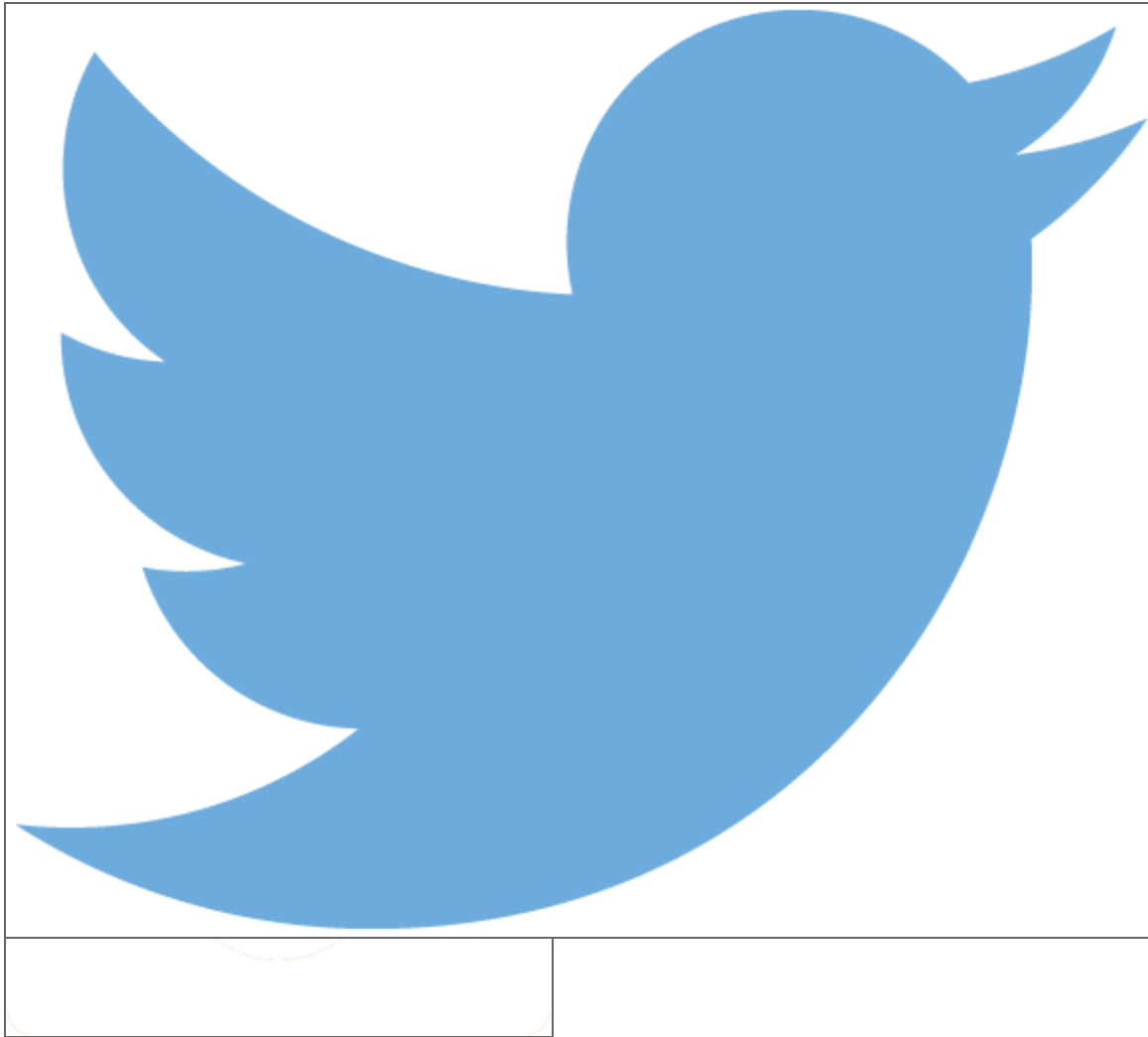


Senhas e chaveiros

Vitor Mattos

incremente sua segurança

Fotografem, comentem, twitem!
@VitorMattosRJ



Olá! Estava no Rio Agile?

Sim, foi show! Aliá, achei a sua apresentação a melhor. Parabéns!

Não conhecia a ferramenta até então, eu estava iniciando ainda meus estudos sobre BDD. Aachei a palestra muito boa mesmo meu nível no assunto sendo muito introdutório.

que trampo foda mano, mt obrg por compartilhar esse conhecimento bro! ou mostrar isso pros devs, talvez isso ajude a engajar os caras a mudar.

Gostei muito da sua palestra, eu que sou iniciante não entendia bem a importância do composer, ficou muito claro que ele é muito útil e como implementar, adorei.

Obrigado por compartilhar esse tão precioso conhecimento conosco.

Nota 10!!! 🍌🍌🍌🍌😊

12:49

Hoje tive a oportunidade de ouvir este grande cara @VitorMattos Deixo aqui os meus parabéns, foi uma grande palestra, valeu cada minuto e espero ver mais o seu trabalho fera, parabéns !

22:46

Quem sou eu?

Desenvolvedor PHP desde 2003

Amante de opensource

Evangelista PHP

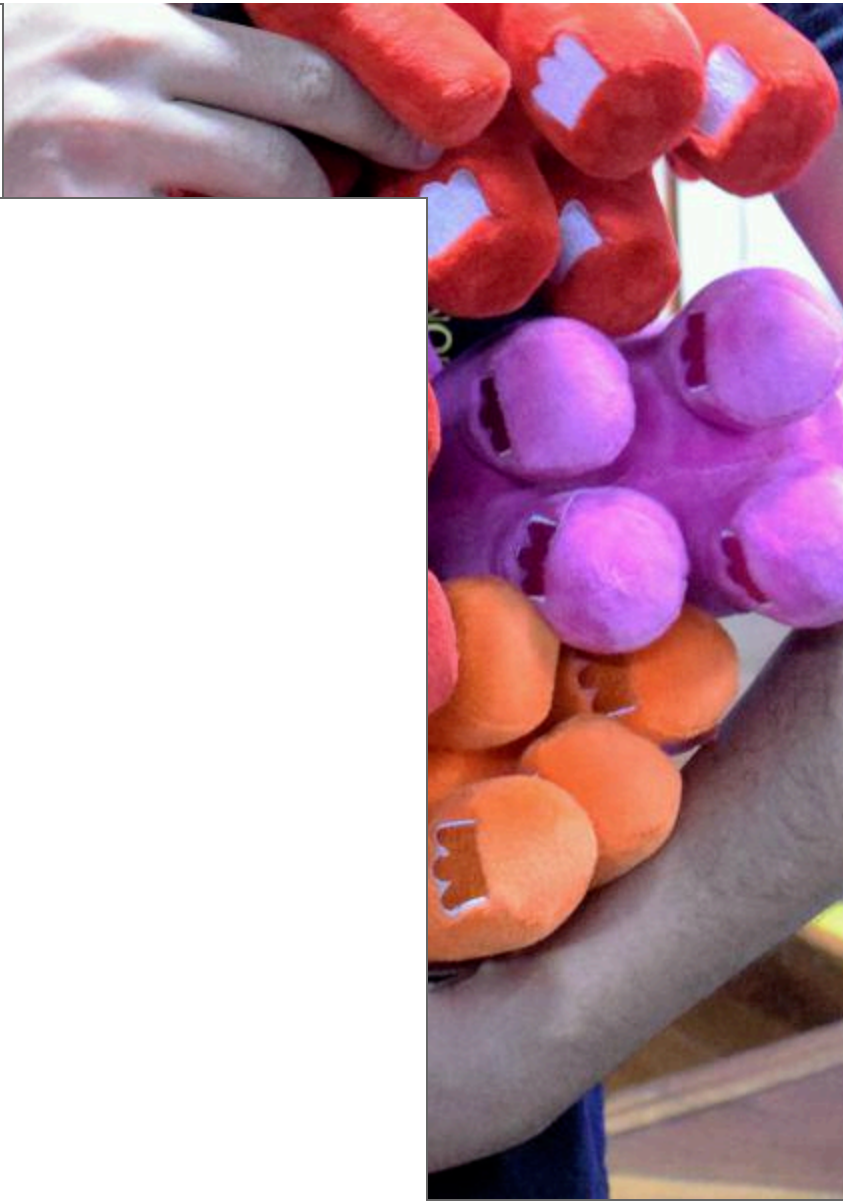
PHP Zend Certified Engineer (**ZEND024235**)

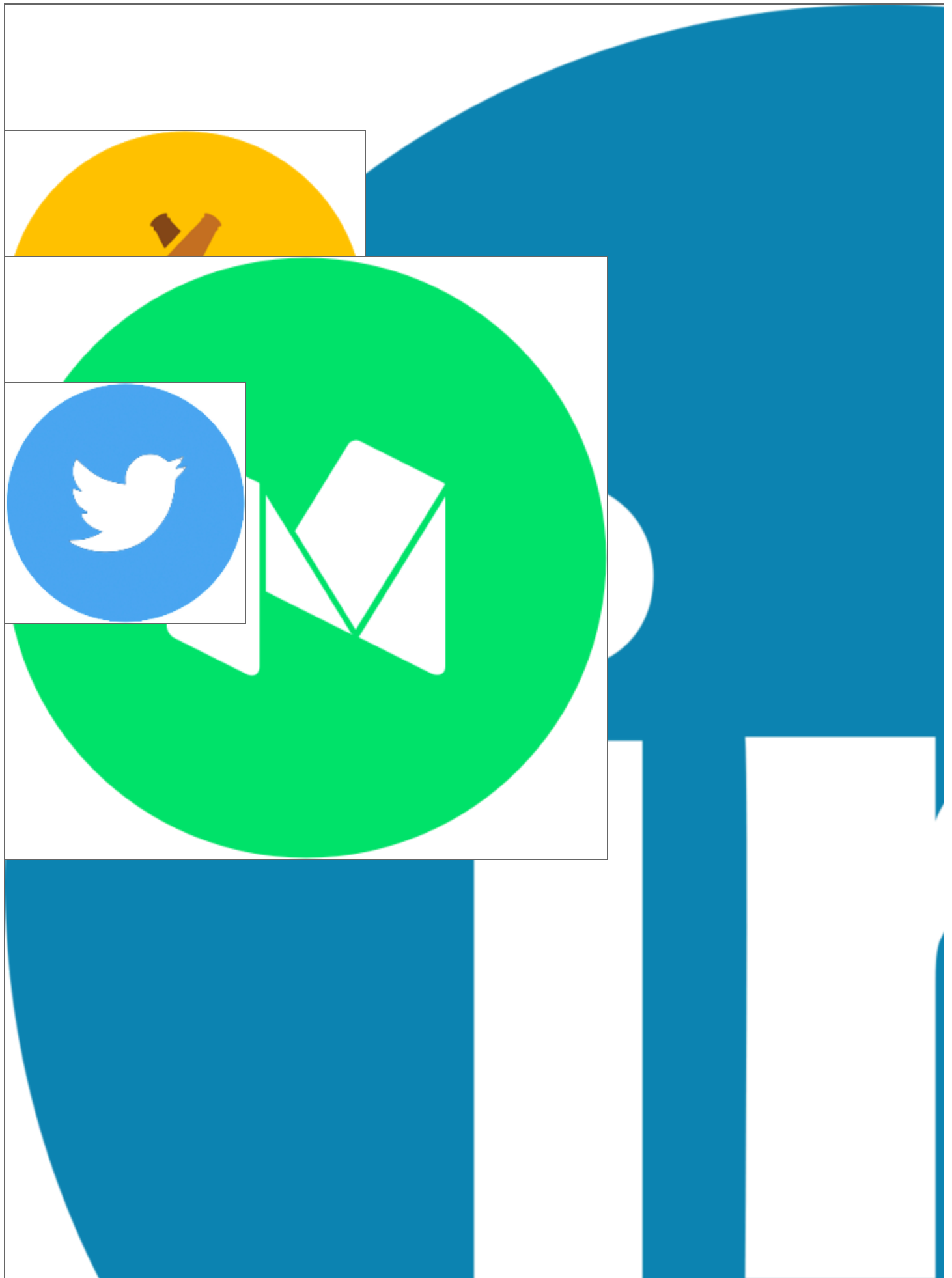
PHPRio (**<https://telegram.me/phprio>**)

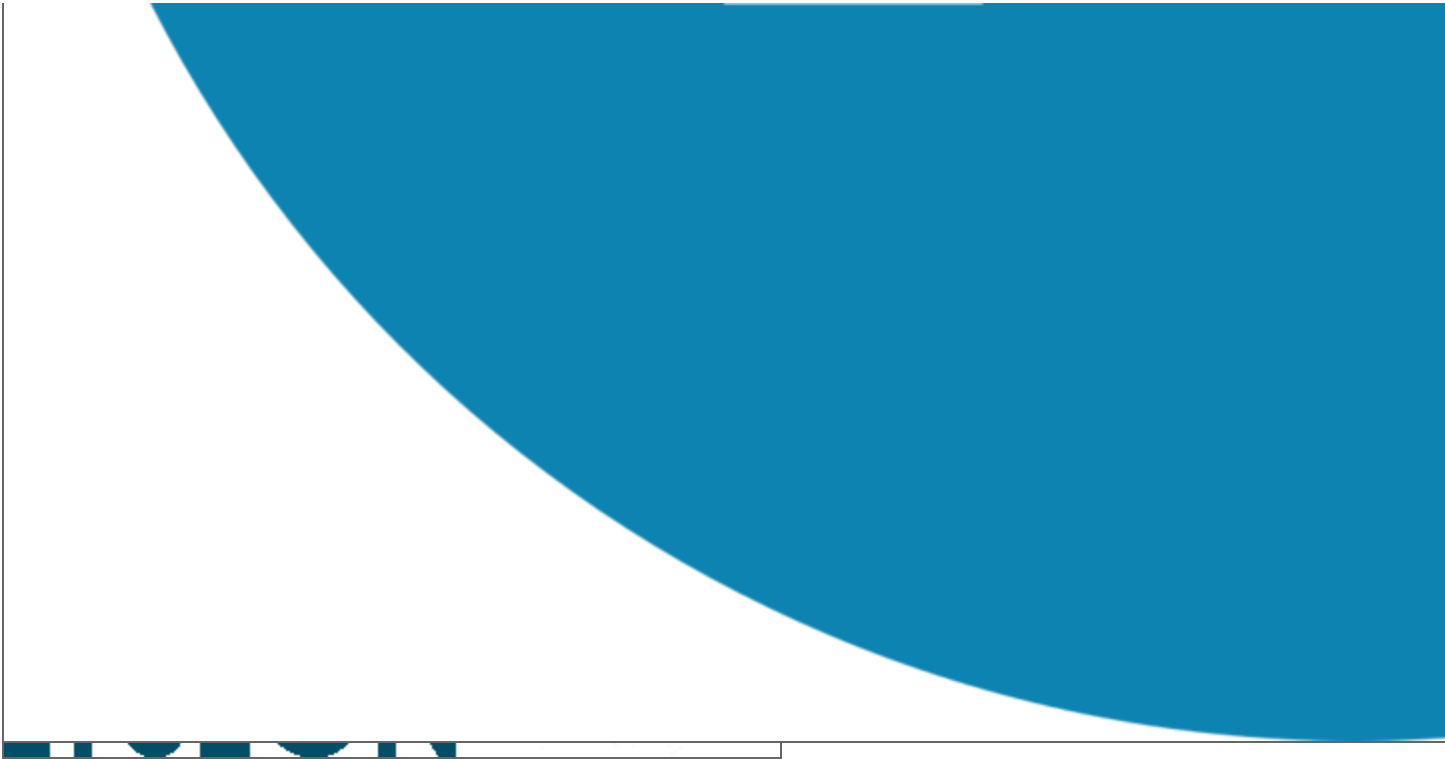
CTO Lyseon Tech

Redes sociais: (VitorMattos ou VitorMattosRJ)









Cronograma

Tentarei ser breve :-D

- Introdução / definições
- Aplicações web
 - ▷ hash
 - ▷ oAuth
 - ▷ 2FA
- Políticas de senhas
- Criando senhas
- Chaveiros de senhas
 - ▷ KeePass

O que é uma senha?



Password

*

*

*

*

*

*

*



O que é secreto?



Dados sensíveis



password username

[Repositories](#)

Code 753K+

[Commits](#) 389K

[Issues](#)

[Marketplace](#)

[Topics](#)

Showing 753,783 available code results ?



cezarydepta/aplikacje_mobilne_2017 – users.json

Showing the top four matches Last indexed on Jul 12

```
1 [{"username":"ckerm0n0", "password":"zaq1@WSX", "email":":  
2 {"username":"opeirpoint1", "password":"zaq1@WSX", "email":":  
3 {"username":"tilywarch2", "password":"zaq1@WSX", "email":":
```

Dados sensíveis
Não versione!

Packagist

vlucas/phpdotenv

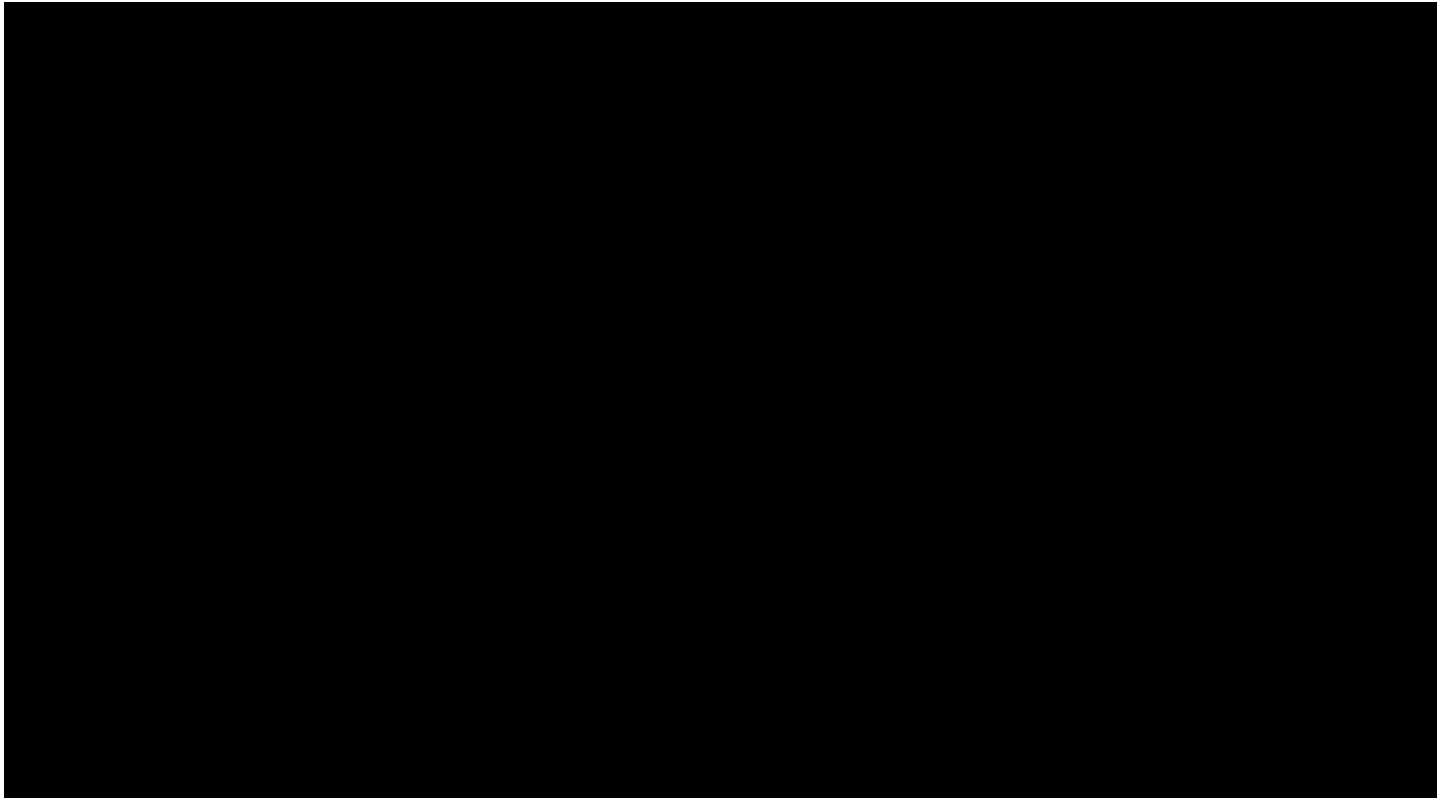
⬇ `composer require vlucas/phpdotenv`

*Loads environment variables from ``.env`` to `getenv()`,
`$_SERVER` automatically.*

Aplicações web

Segurança de aplicações web

Vitor Mattos



Armazenamento: hash

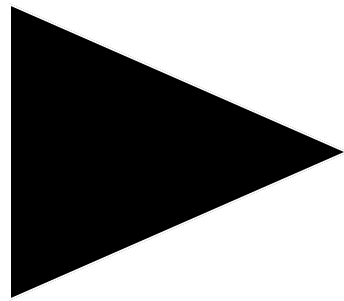
Definição: "transformação de uma grande quantidade de dados em uma pequena quantidade de informações"

Função de mão única

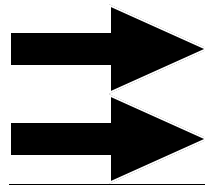
Mensagem

Entrada

01010010010101010100101010101010111001010100101001010:



função
hash



10101101

Saída

Tamanho fixo

plain/text, base64, md5, sha1

```
INSERT INTO login (username, password)
VALUES ('admin', '123456');
mysql_query("INSERT INTO login (username, password)
VALUES ('admin', '".base64_encode('12345678')."')");
mysql_query("INSERT INTO login (username, password)
VALUES ('admin', '".md5('12345678')."')");
mysql_query("INSERT INTO login (username, password)
VALUES ('admin', '".sha1('12345678')."')");
```





Evitando Rainbow Table

Evitando Rainbow Table



e10adc3949ba59abbe56e057f20f883e

Web Images Videos News

☐ Brazil ▼ Safe Search: Off ▼ Any Time ▼

MD5 Password lookup e10adc3949ba59abbe56e057f20f883e
 Password Decoder Provided by HAQ 4 U.com e10adc3949ba59abbe56e057f20f883e
 MD5 is 123456 reverse MD5 is 123456

 e10adc3949ba59abbe56e057f20f883e.haq4u.com

MD5(123456) = e10adc3949ba59abbe56e057f20f883e :: Ge
 MD5("123456") = e10adc3949ba59abbe56e057f20f883e SHA1("123456") =
 7c4a8d09ca3762af61e59520943dc26494f8941b SHA224("123456" ...
<https://tool-bar.appspot.com/hash?input=123456>

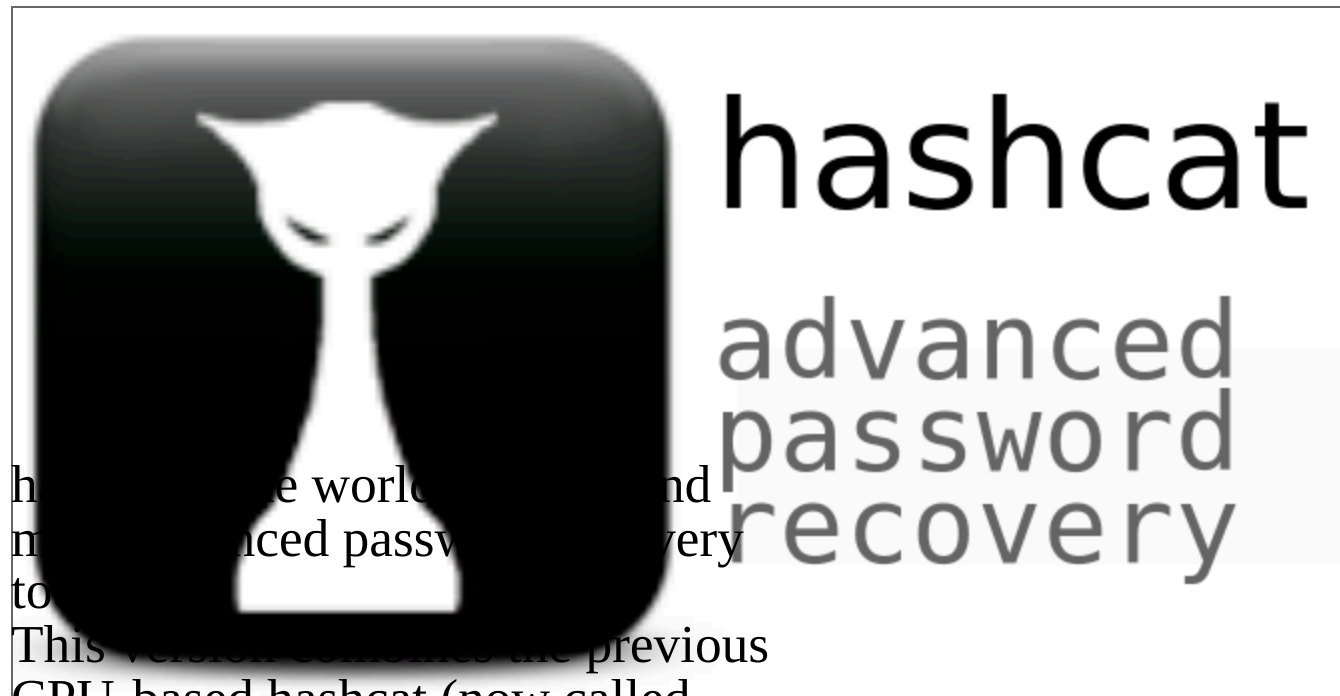
password_hash

```
php > for($i=1;$i<=3;$i++)
php > echo password_hash("Vitor Mattos", PASSWORD_DEFAULT,
    $2y$10$DT0scwr0cP28mb.J0edvOKmmHd
    $2y$10$Dmfc8Dc9ohV2lKnOjk5IxeHCos6A
    $2y$10$RvIAfjB3CX8ZmwjCT8boL.Wi8pFl
    var_dump(password_verify(
        "Vitor Mattos",
        "$2y$10$Dmfc8Dc9ohV2lKnOjk5IxeHCos6A
    ));
Criando hash
Validando hash
true
```

Corrigindo o problema

```
if ($hash == md5($_POST['password'])) {  
    $hash = password_hash(  
        $_POST['password'],  
        PASSWORD_DEFAULT  
    );  
    $db->exec(  
        "UPDATE login SET password = ? WHERE  
    );  
}
```

Bruteforce



hashcat is the world's fastest and most advanced password recovery tool.

This version combines the previous CPU-based hashcat (now called **hashcat-legacy**) and GPU-based **oclHashcat**.

Hashcat is **released** as open source software under the **MIT** license.

Cluster GPU

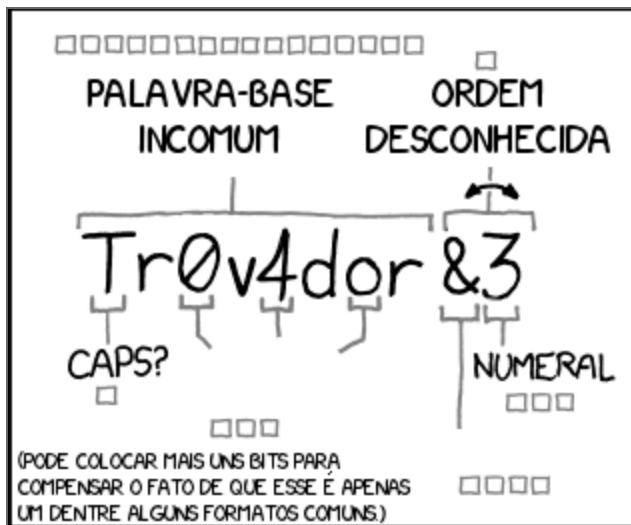


25 GPU
force 348 billion
hashes per
second to crack
your passwords

Cálculo de complexidade

Entropia: "média de informação transmitida por um evento, quando considera todos os resultados possíveis"

<https://github.com/vitormattos/crack-password-calc>



~28 BITS DE ENTROPIA

□□□□□□□□
 □□□□□□□□
 □□□□
 □□□□

$2^{28} = 3 \text{ DIAS}$
 COM 1000
 TENTATIVAS/SEGUNDO
 (ATAQUE PLAUSÍVEL EM UM SITE WEB FRÁGIL. QUEBRAR HASHS ROUBADOS É MAIS RÁPIDO, MAS NÃO É COM O QUE O USUÁRIO COMUM SE PREOCUPA)

DIFICULDADE DE QUEBRAR:

FÁCIL

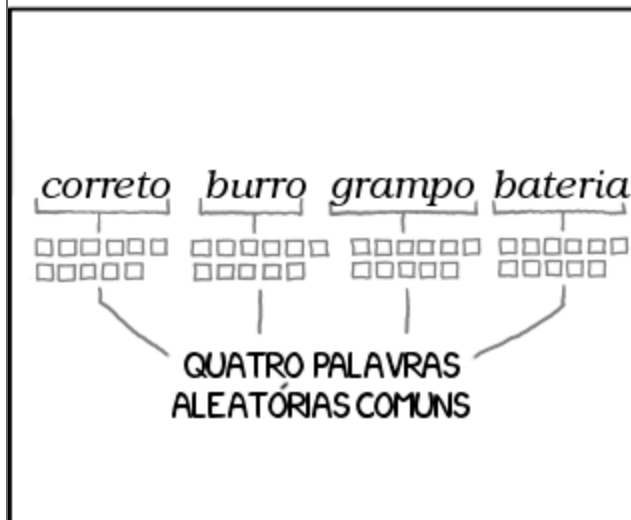
ERA TROCADOR? NÃO, ERA TROVADOR. E UM DOS 0s ERA ZERO?

E TINHA AQUELE SÍMBOLO...



DIFICULDADE DE LEMBRAR:

DIFÍCIL



~44 BITS DE ENTROPIA

□□□□□□□□□□
 □□□□□□□□□□
 □□□□□□□□□□
 □□□□□□□□□□

$2^{44} = 550 \text{ ANOS}$
 COM 1000
 TENTATIVAS/SEGUNDO

DIFICULDADE DE QUEBRAR:

DIFÍCIL

UM GRAMPO DE BATERIA!

CORRETO!



DIFICULDADE DE LEMBRAR:

VOCÊ JÁ MEMORIZOU

DEPOIS DE 20 ANOS DE ESFORÇO NÓS CONSEGUIMOS EFETIVAMENTE TREINAR TODO MUNDO A USAR SENHAS QUE SÃO DIFÍCEIS PARA OS HUMANOS MEMORIZAREM, MAS FÁCEIS PARA OS COMPUTADORES ADIVINHAREM..

Bruteforce

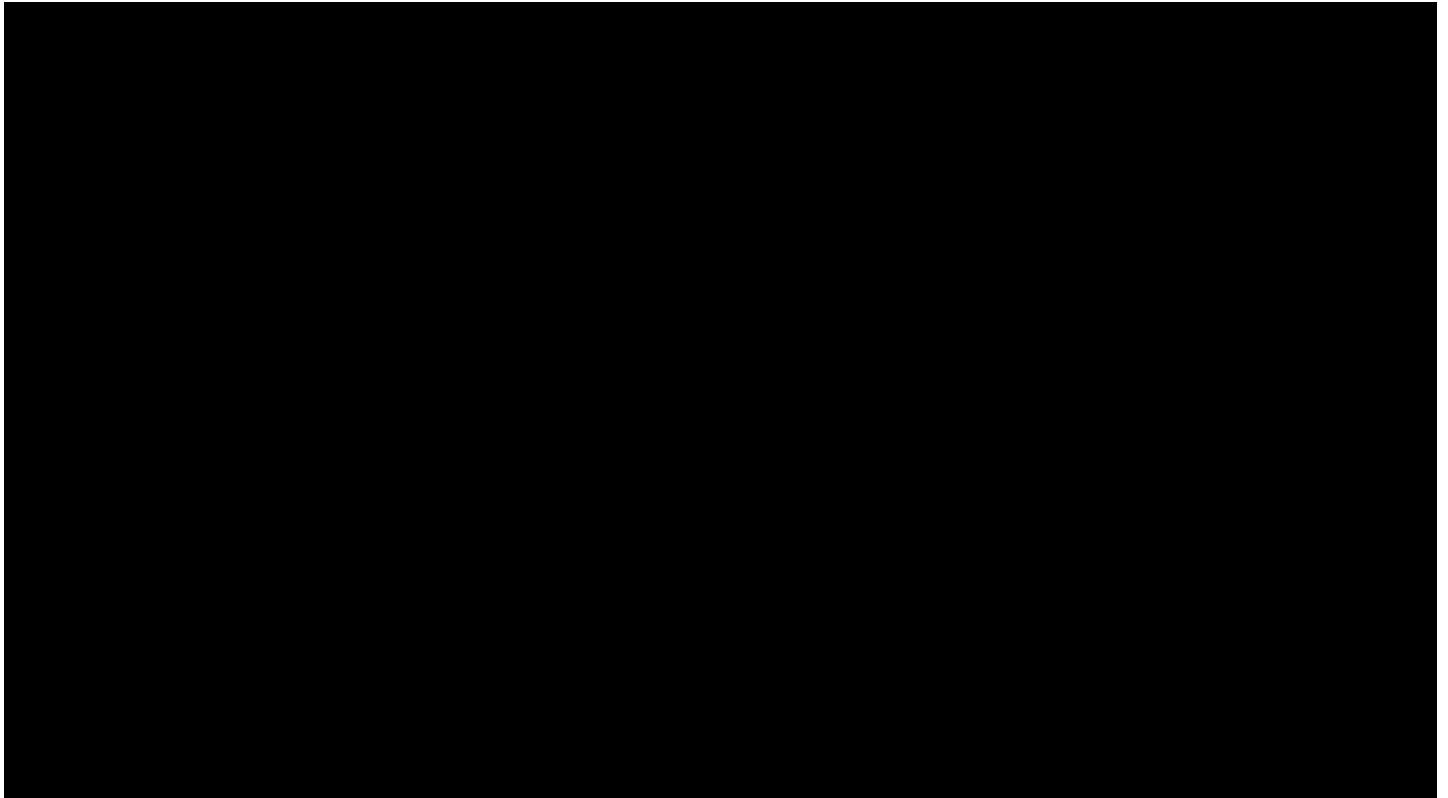
Bruteforce

Senhas complexas e pequenas só são difíceis de decorar, mas continuam sendo simples de quebrar.

Resolvendo o problema de bruteforce em aplicações web

Segurança de aplicações web

Vitor Mattos



oAuth



oAuth

Segurança

"Facebook hackeado:
ataque atinge 50 milhões
de usuários"
2018-09-28



Continue with Google



Continue with Facebook



Continue with Email

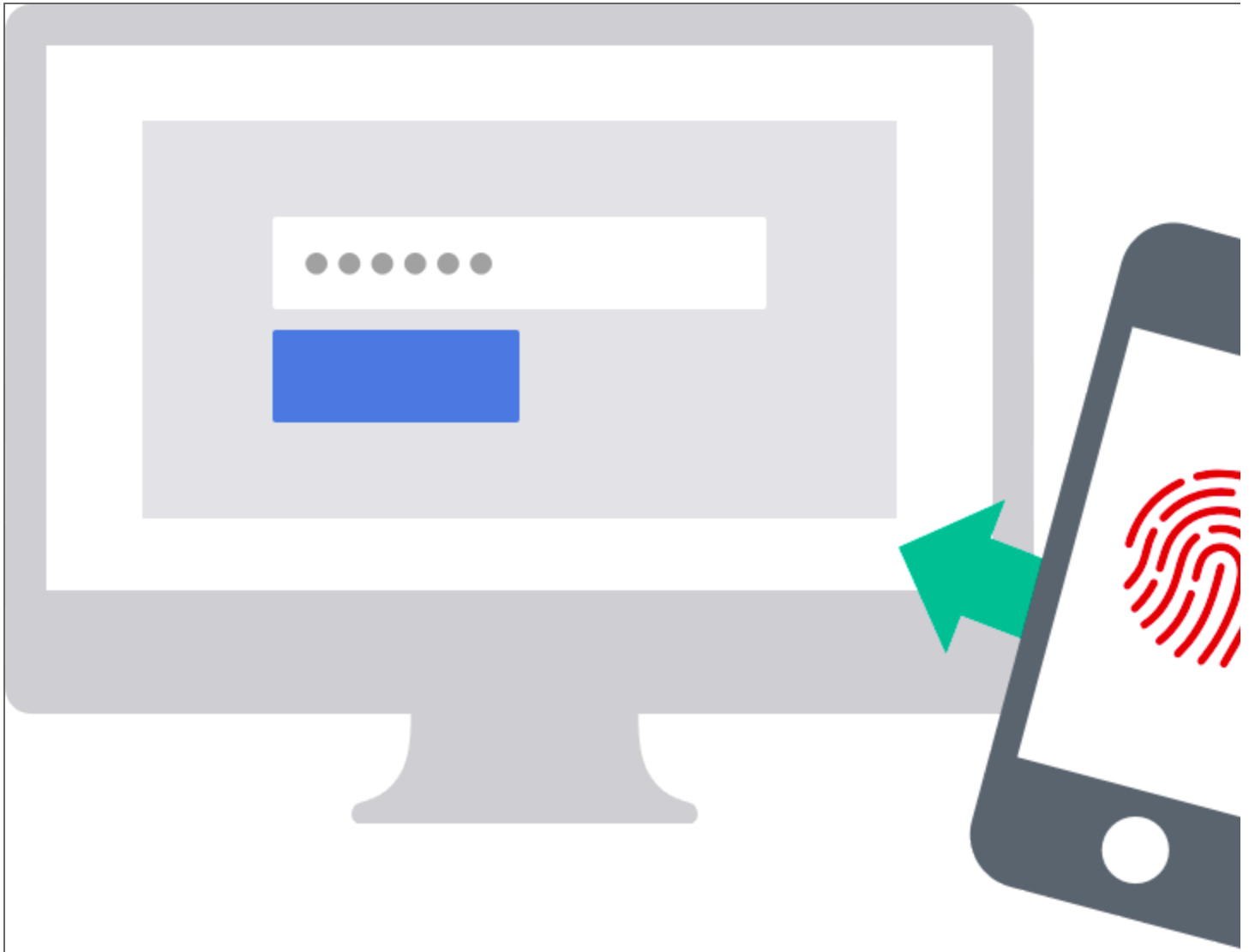


oAuth

Privacidade



2FA, 3FA, 4FA, ..., nFA



2FA, 3FA, 4FA, ..., nFA

Quem aceita?

<https://twofactorauth.org/>



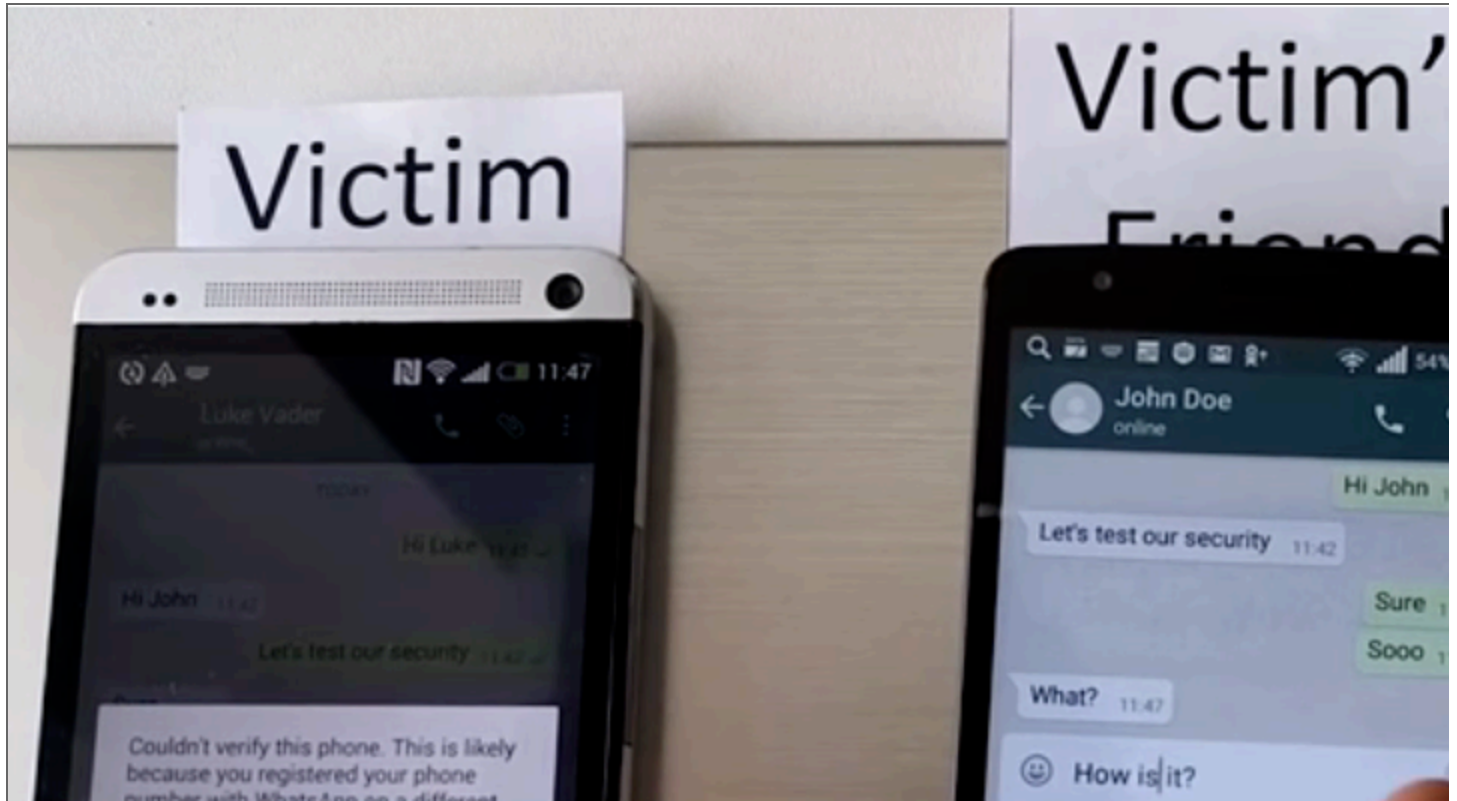
Two Factor Auth (2FA)

List of websites and whether or not they support [2FA](#).

Add your own favorite site by submitting a pull request on the [GitHub repo](#).

 Search websites

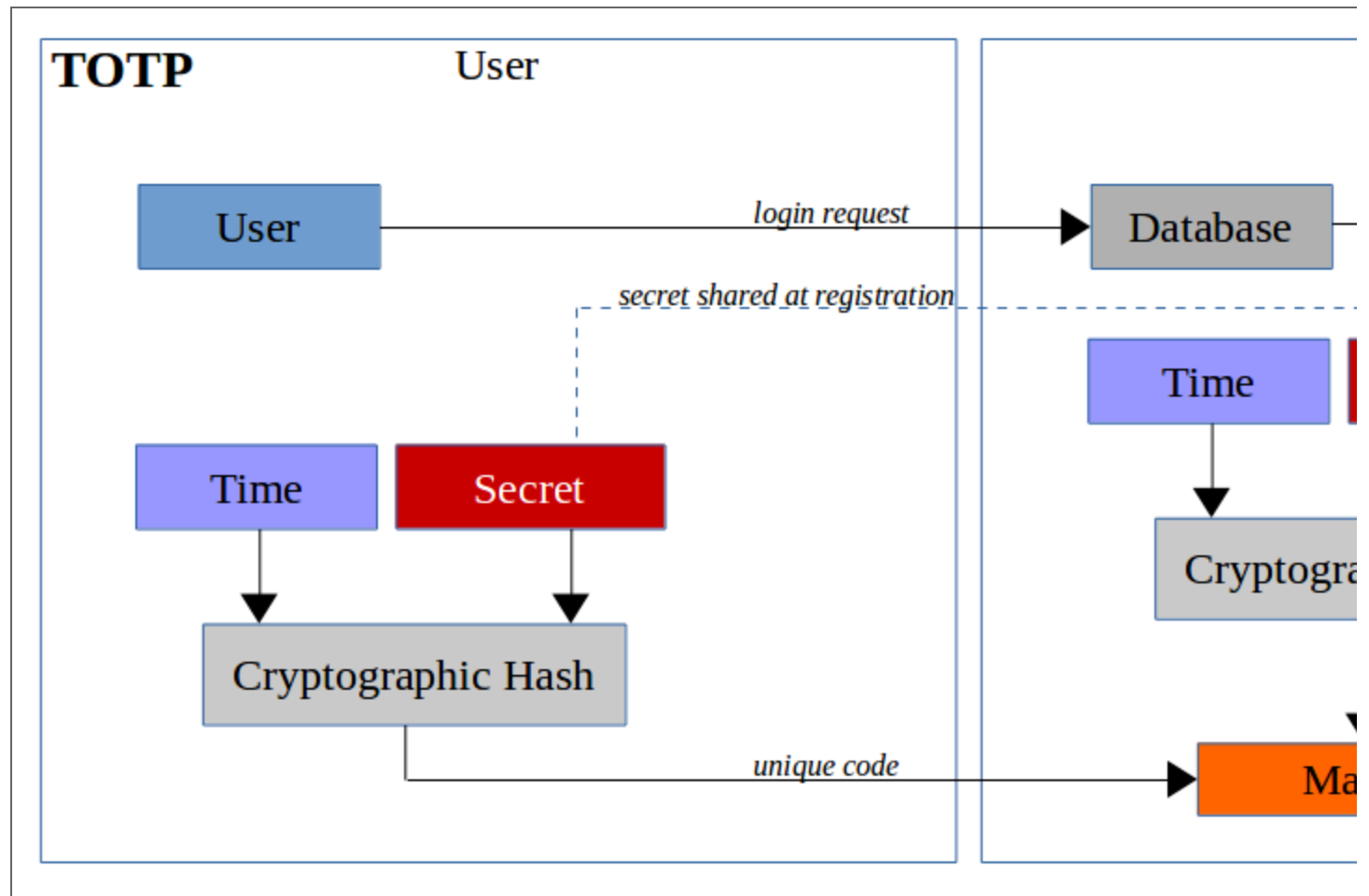
2FA, 3FA, 4FA, ..., nFA Token SMS



2FA, 3FA, 4FA, ..., nFA

TOTP, o que é?

"Time-based One-Time Password algorithm (TOTP)"



2FA, 3FA, 4FA, ..., nFA Hardware de TOTP



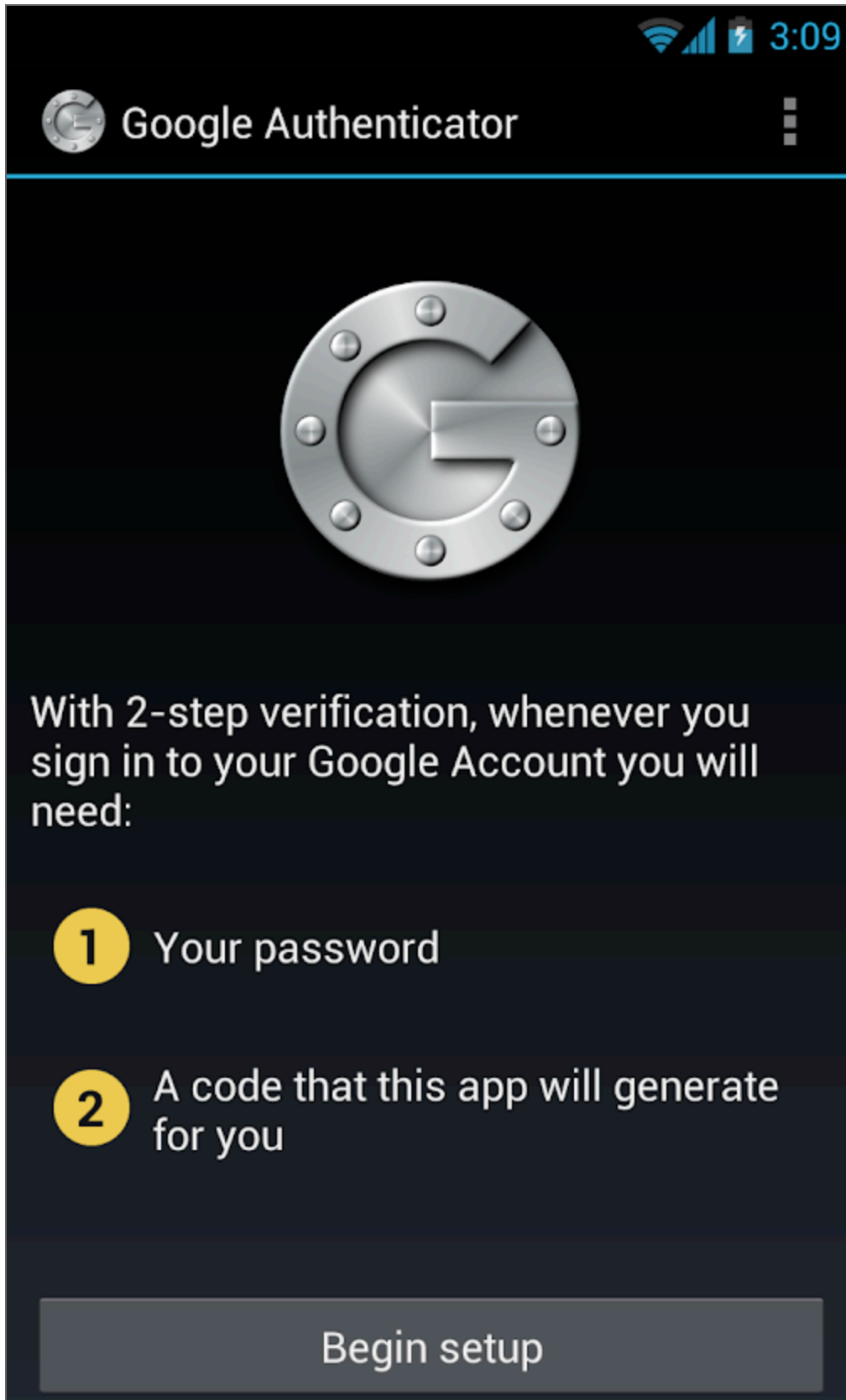
2FA, 3FA, 4FA, ..., nFA

Hardware de TOTP: riscos



2FA, 3FA, 4FA, ..., nFA

TOTP no celular



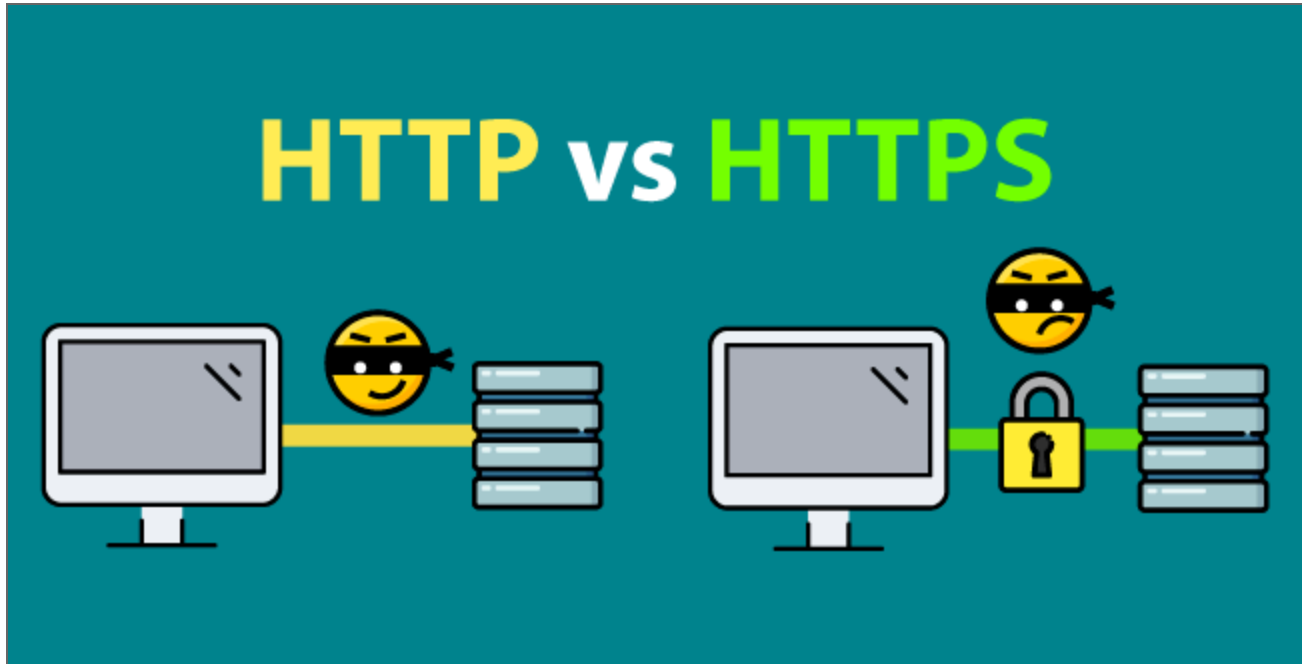


2FA, 3FA, 4FA, ..., nFA

TOTP no celular: riscos



Prefira sempre HTTPS



Política de senhas

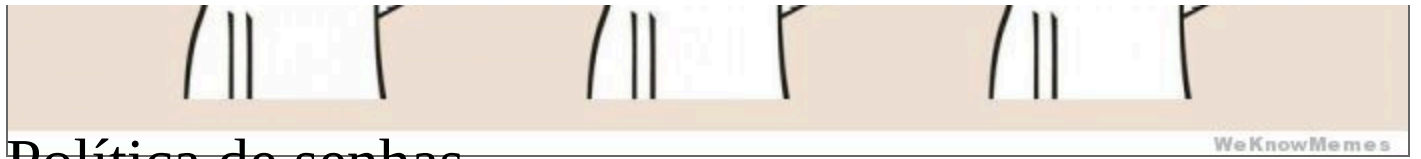


Política de senhas

"Sorry, your password must contain a capital letter, two numbers, a symbol, an inspiring message, a spell, a gang sign, a hieroglyph and the blood of a

Desculpe, sua senha deve conter uma letra maiúscula, dois números, um símbolo, uma mensagem inspiradora, um feitiço, um sinal de gangue, um hieróglifo e o sangue de uma virgem."





Política de senhas

Limite máximo



Criando senhas Vazamento





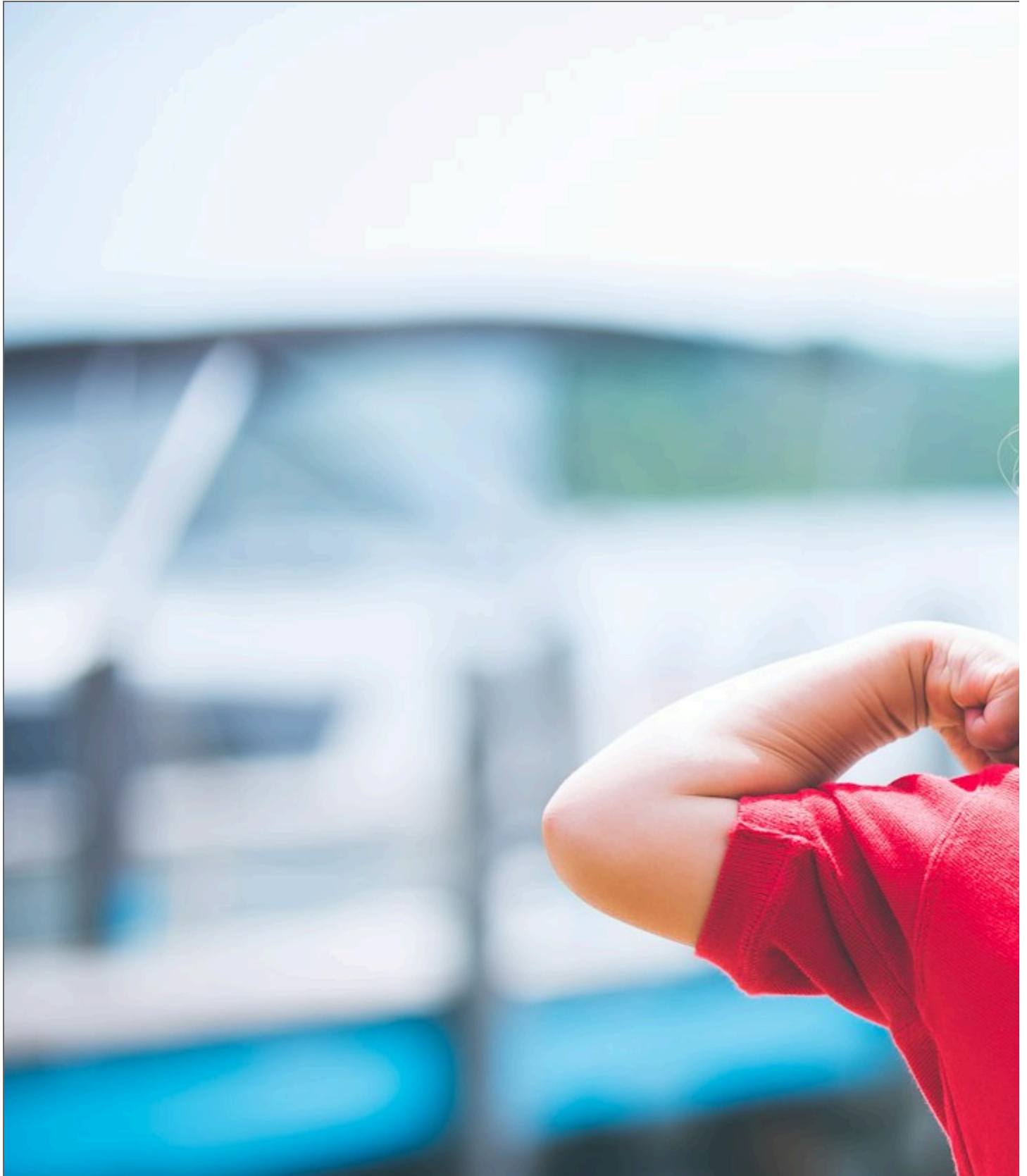
Criando senhas

Vazamento: senhas comuns



Criando senhas

Vazamento: toda senha deve ser forte



Criando senhas
trate sua senha como sua escova
de dente



Escolha uma boa
Nunca compartilhe
Troque com certa frequência

Criando senhas

Evite:

- informações pessoais
- redes sociais revelam senhas
- observadores

Criando senhas
Evite: anotar senhas

A **password** for the **Hawaii** emergency agency
written on a **post-it** note read.bi/2DB4RRz



19



166



229



Criando senhas

Evite: salvar em arquivos abertos

/*/senhas.txt

/*/password.txt

/*/senhas.xlsx

Criando senhas

Faça:

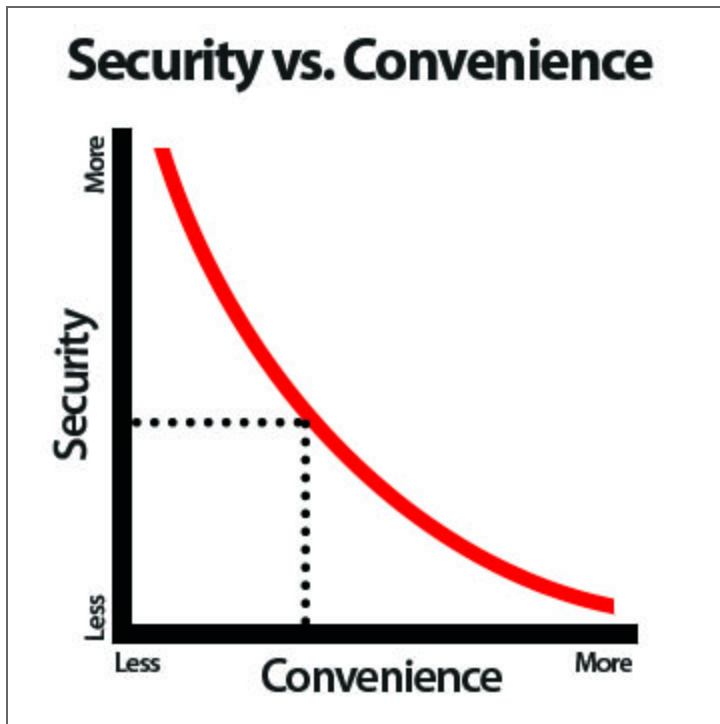
- passphrase
- senhas únicas
- caracteres especiais e aleatórios
- distribuição de proporcional de caracteres
- senhas longas
- mude se alguém criou

Senhas geradas por humanos

- baixa entropia
- Memória humana falha



Segurança x Conveniência



Chaveiros de senhas: O que são?



Chaveiros de senhas:

porque usar?

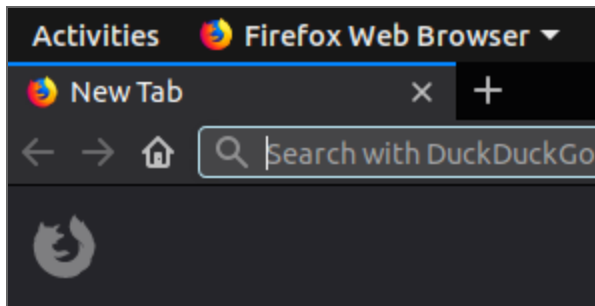
Senhas grandes - entropia

Senhas únicas

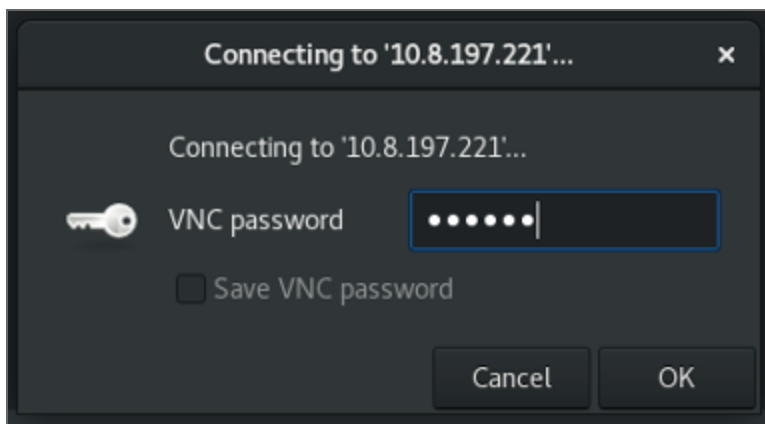
Não perder senhas

Ocupar a mente com o que é importante

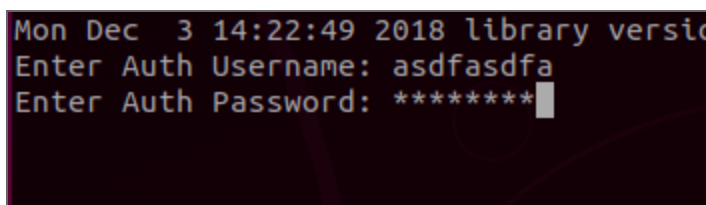
Onde usar?



Navegadores



Aplicações desktop



Terminal

Celular

Chaveiros de senhas:

Riscos: Salvar no navegador

- Nem sempre se tem backup
- Extensões maliciosas
- Alguém pode usar seu pc

Chaveiros de senhas: Riscos: Chaveiro na nuvem

lifehacker | VIDEO SKILLET TWO CENTS VITALS OFFSPRING THE UPGRADE APP DI

LastPass Hacked, Change Your Master Password Now

 Eric Ravenscraft
6/15/15 3:30pm • Filed to: HACKED ▾

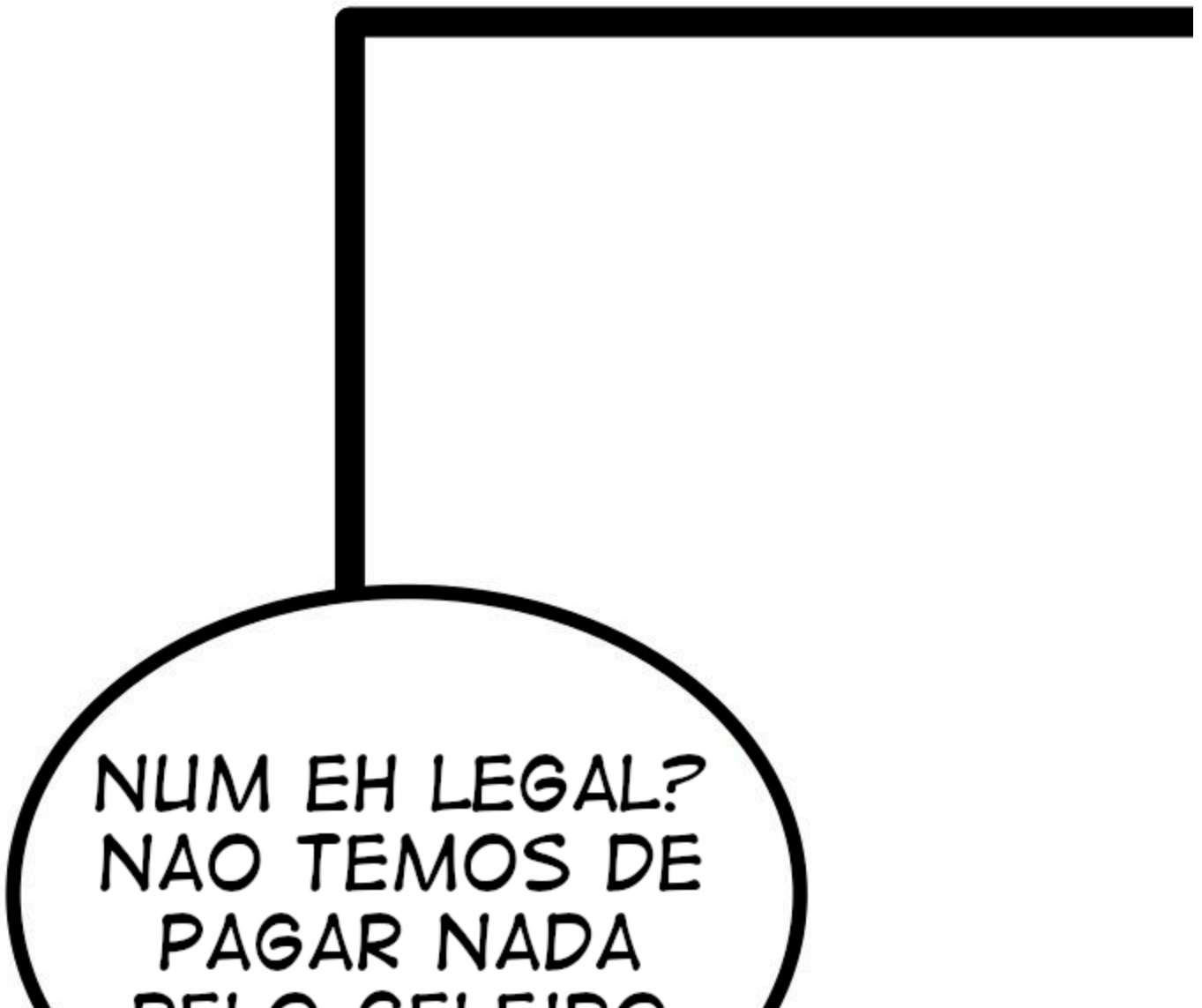
 297.5K  250  16  



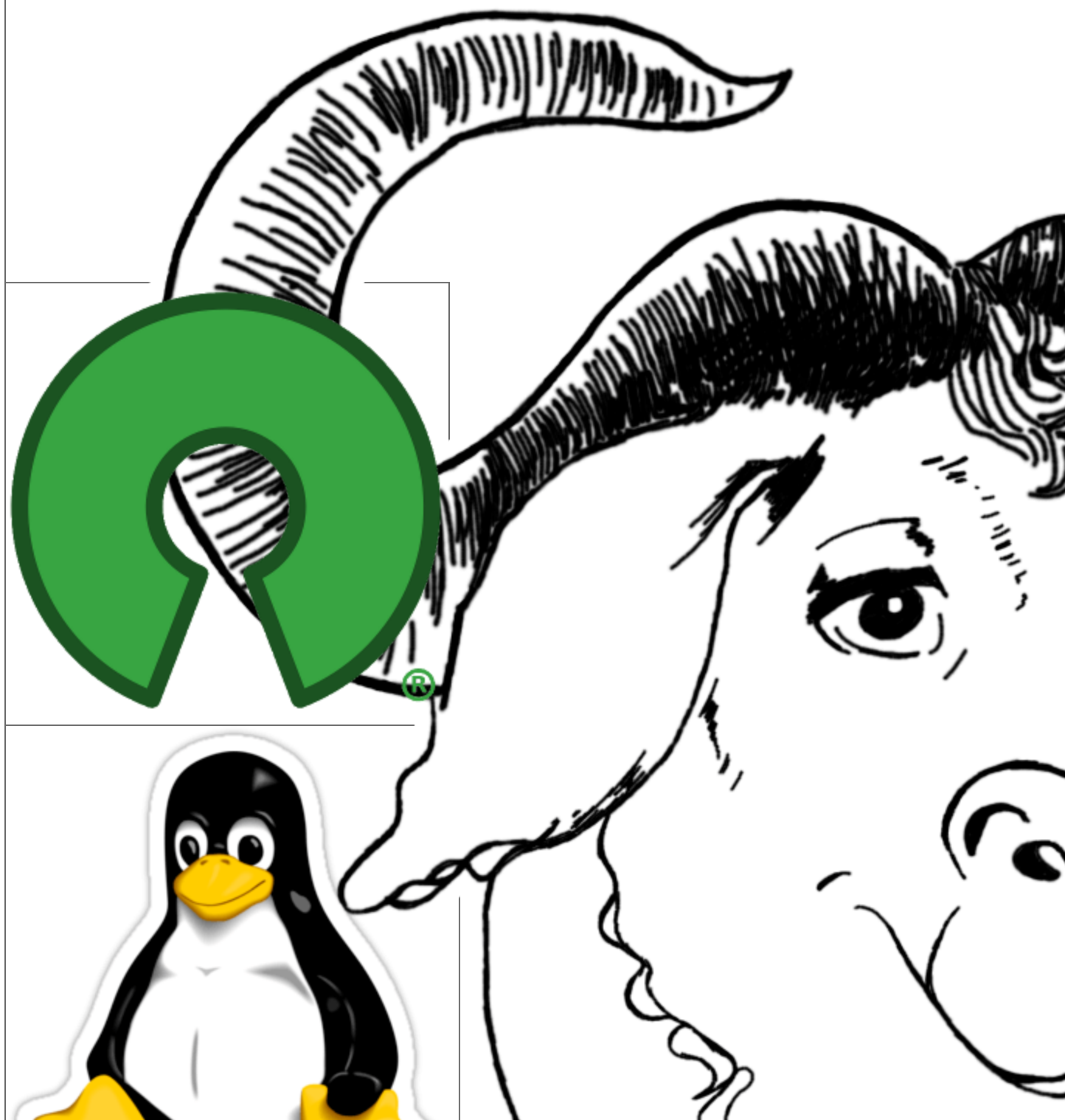
Chaveiros de senhas:

Riscos: Terceiros guardarem suas senhas

Google e outros serviços de chaveiro online proprietários



OpenSource





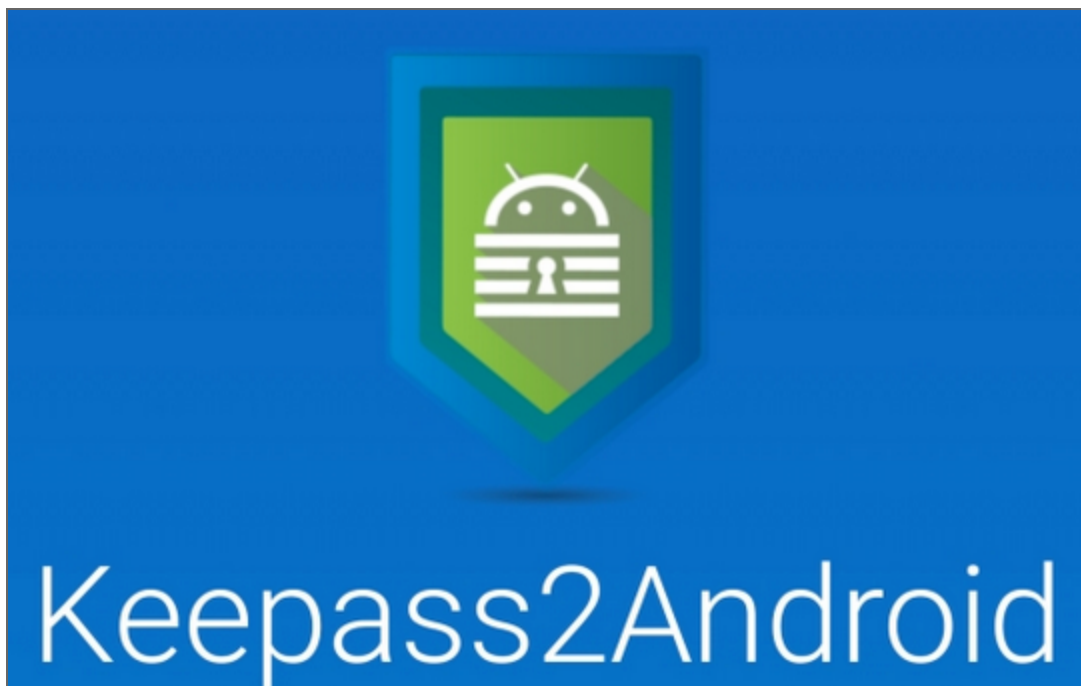
4 liberdades do software livre

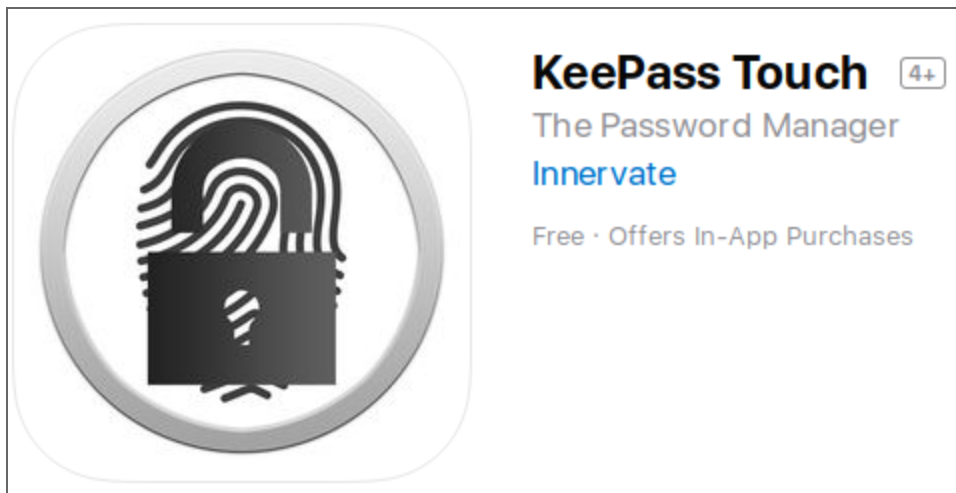
Liberdade nº 0: A liberdade para executar o programa, para qualquer

Liberdade nº 1: A liberdade de estudar como o programa funciona, e
necessidades. Acesso ao código-fonte é um pré-requisito para esta li

Liberdade nº 2: A liberdade de redistribuir de forma que você possa

Chaveiros livres: KeePass





Clientes

KeePass



É multiplataforma.
Funciona em sistemas Linux mas precisa do Mono, fica meio feio

Clientes

KeePassX



Como o nome já diz, cross platform.

Problema: o projeto está meio abandonado, o mantenedor não aceita Pull Request faz um tempo

Cientes

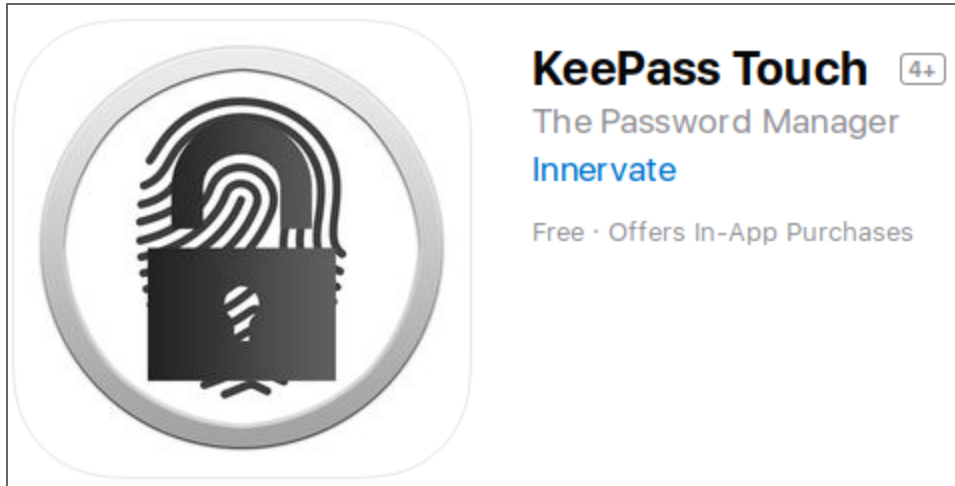
KeePassXC



Um fork do KeePassX...

Só que mantido pela comunidade, este aceita PR e é um projeto bem ativo.

Cientes Celular

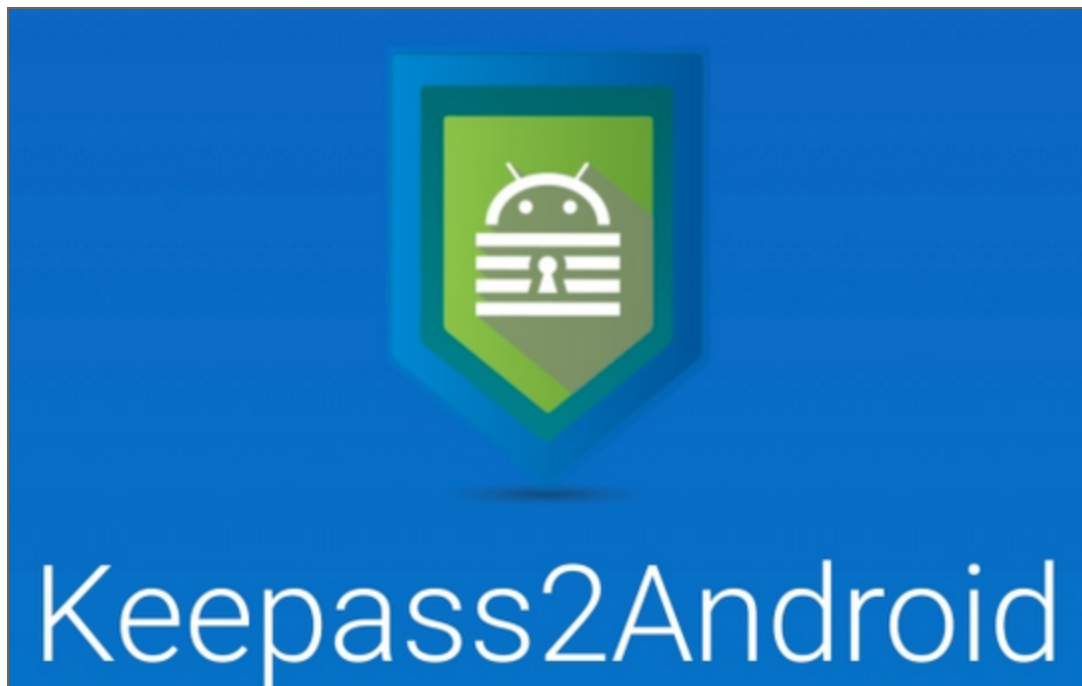


Para iPhone, nunca usei, nem quero usar. 🤪

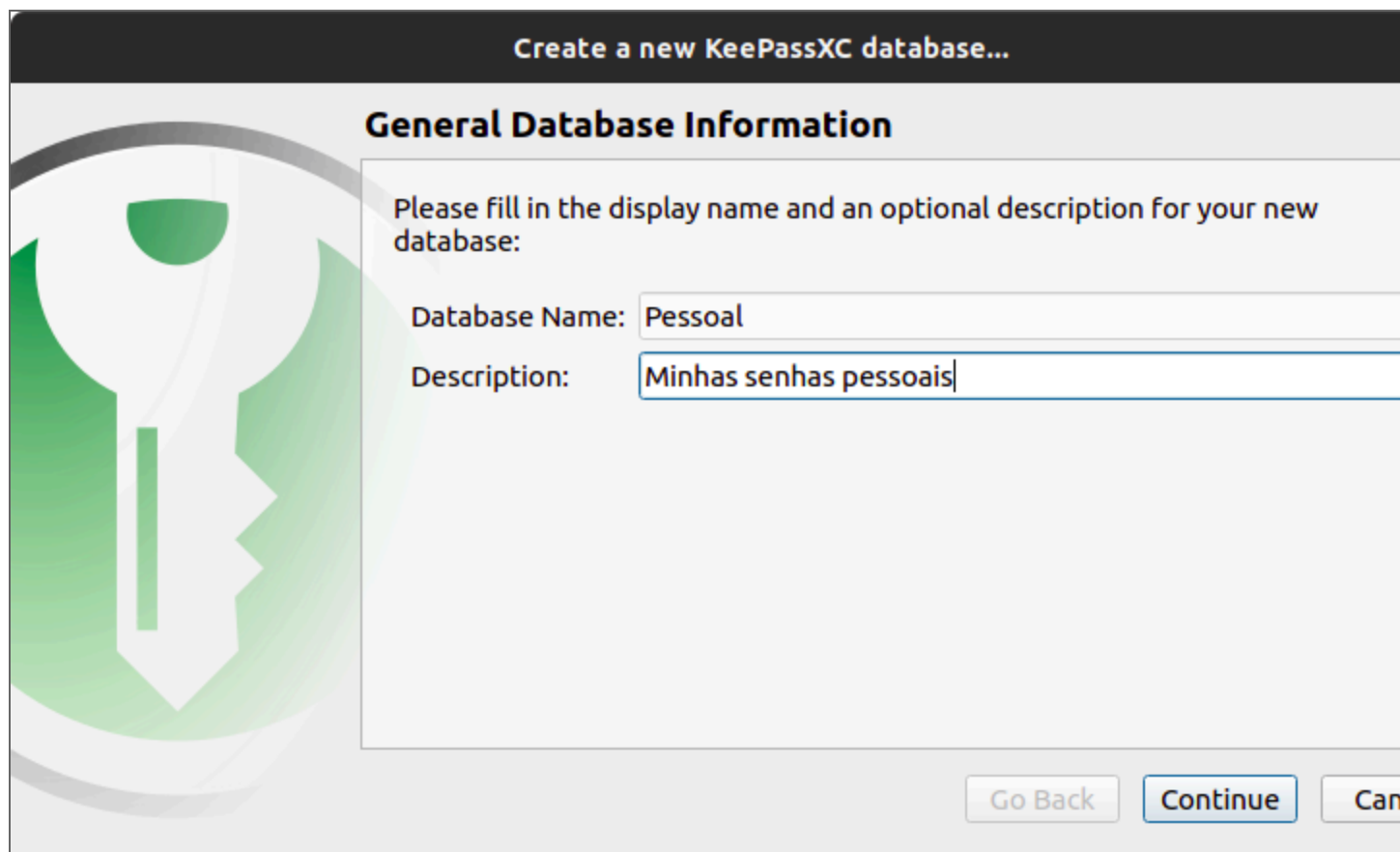
Cientes

Celular

- Interface bem amigável
- Teclado exclusivo (facilita muito)
- Aceita plugins
- Desbloqueio biométrico (nunca testei)
- Sincronismo da base de dados com vários lugares diferentes
- Pode abrir várias bases de dados simultaneamente
- Autocomplete (Andriod ≥ 8)



Criando o primeiro chaveiro



The screenshot shows the 'Create a new KeePassXC database...' dialog box. On the left is a large green key icon. The main area is titled 'General Database Information' and contains the instruction: 'Please fill in the display name and an optional description for your new database:'. Below this are two text input fields. The first field is labeled 'Database Name:' and contains the text 'Pessoal'. The second field is labeled 'Description:' and contains the text 'Minhas senhas pessoais'. At the bottom right of the dialog are three buttons: 'Go Back', 'Continue', and 'Can' (partially visible).

Create a new KeePassXC database...

General Database Information

Please fill in the display name and an optional description for your new database:

Database Name:

Description:

Criando o primeiro chaveiro



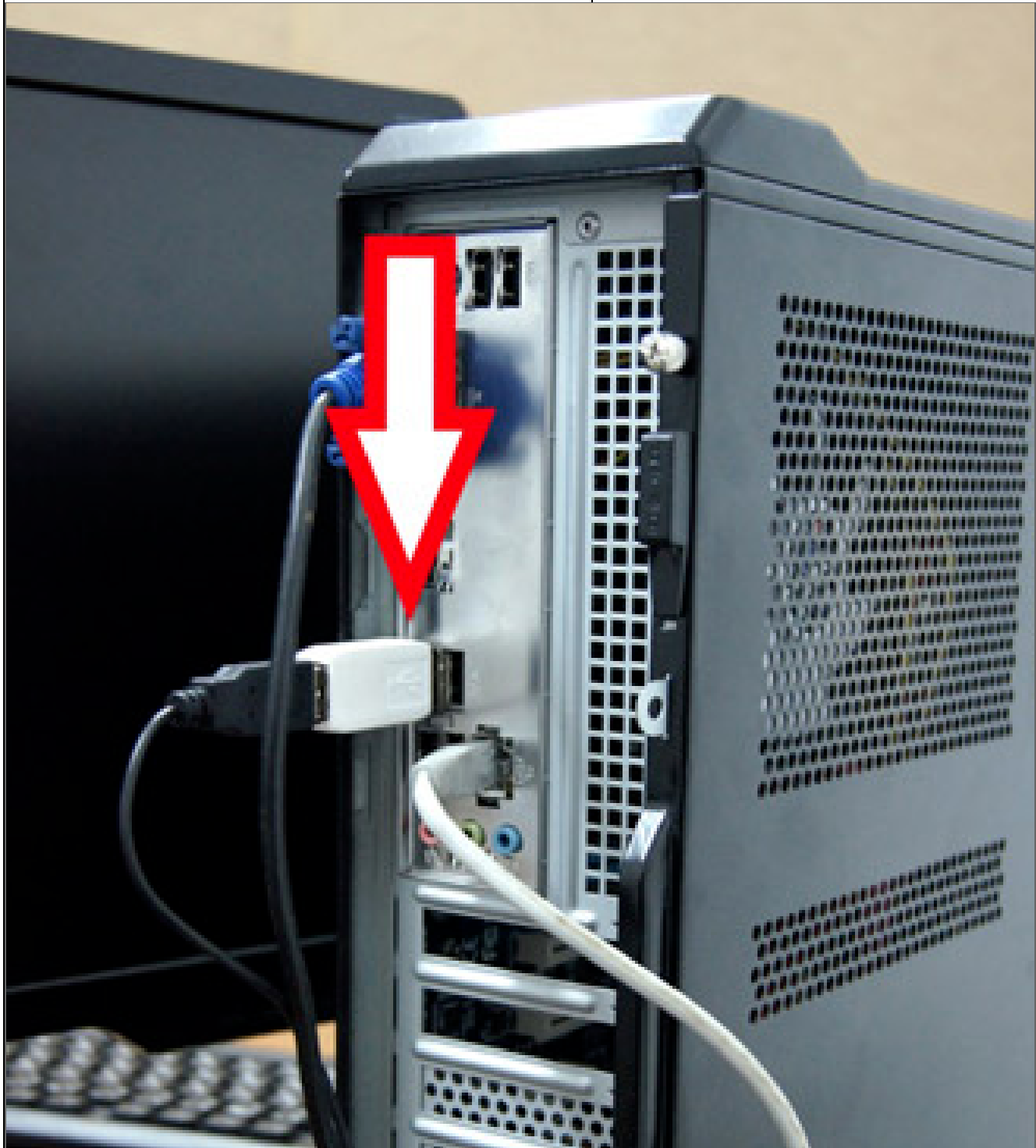
Senha mestre

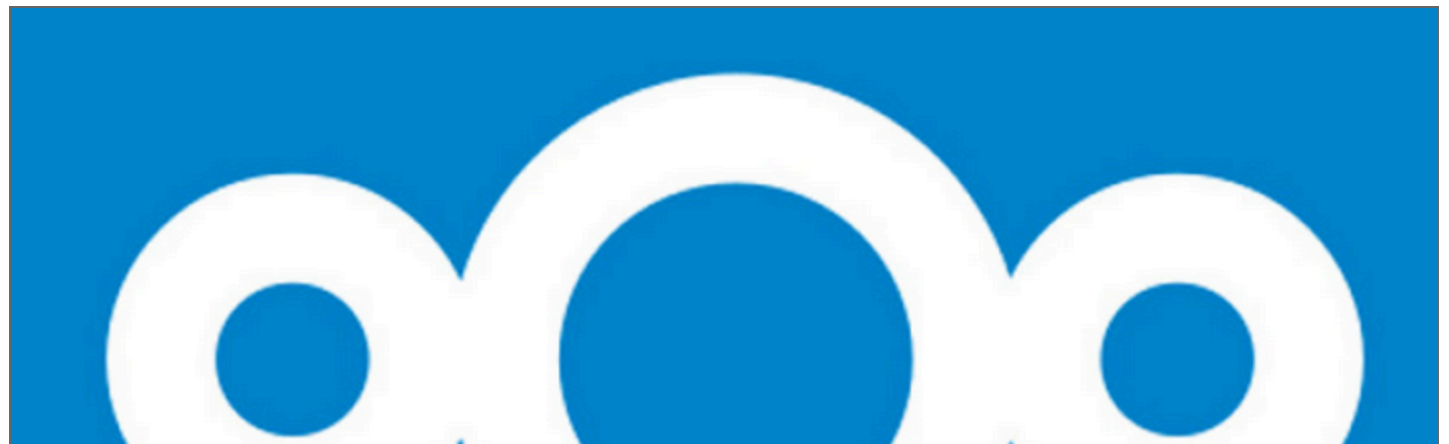
- Troque de vez em quando
- Esta deve ser complexa
- Multifator
- Bloquear chaveiro ao bloquear máquina
- Cuidado com pessoas observando
- Não confie em sua memória, tenha alguém de confiança para backup da senha

Senha mestre

Use em computadores seguros:

Keyloggers





Proprietários



Criando a base de dados

Diferentes bases para diferentes fins

- Clientes
 - ▷ Empresa A
 - ▷ Empresa B
- Pessoas
- Outras pessoas

Novo registro

O que salvar no chaveiro?

- Senhas (dãããhh)
- Dados de documentos
- Dados de cartões
- Anotações secretas diversas
- Chaves de SSH
- Outras chaves de autenticação
- Mapa do tesouro

Novo registro

Geração de senhas

Password: 'Á)>^åx" j îºuîÂÿ?»báåµ}Ôûú¶ô9Ô"¼*\$Æ_ºXKäë¼^k® 

Password Quality: Excellent Entropy: 1926.09 bit

Password Passphrase

Length:  256

Character Types

A-Z 0-9 .,:; <+!?= #\$_%&@^`~ Simple

a-z {[(" ' _ | - / ExtendedASCII

Do not include: #  Hex

☒ Exclude look-alike characters

☒ Pick characters from every group

Regenerate

Copy

Close

Novo registro

Campos extras

Additional attributes

CVV

Expire

Expire month

Expire year

First name

Last Name

Name

Number

[PROTECTED] Press reveal to view or edit

Add

Remove

Edit Name

☒ Protect

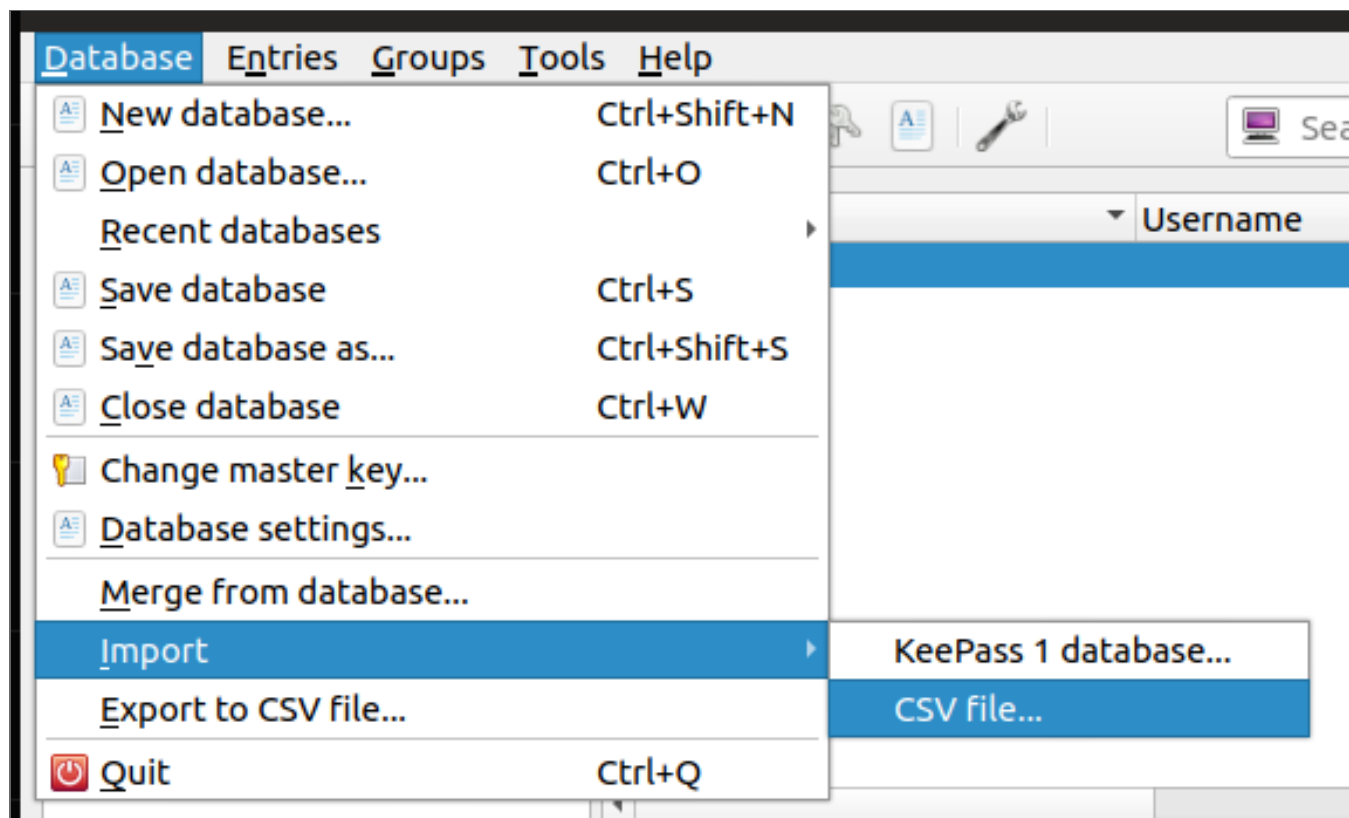
Reveal

Attachments

Name	Size	
vitor.pem	1,87 KiB	Add Remove Open Save

Novo registro

Importação de senhas



Autotype

Tecla de atalho

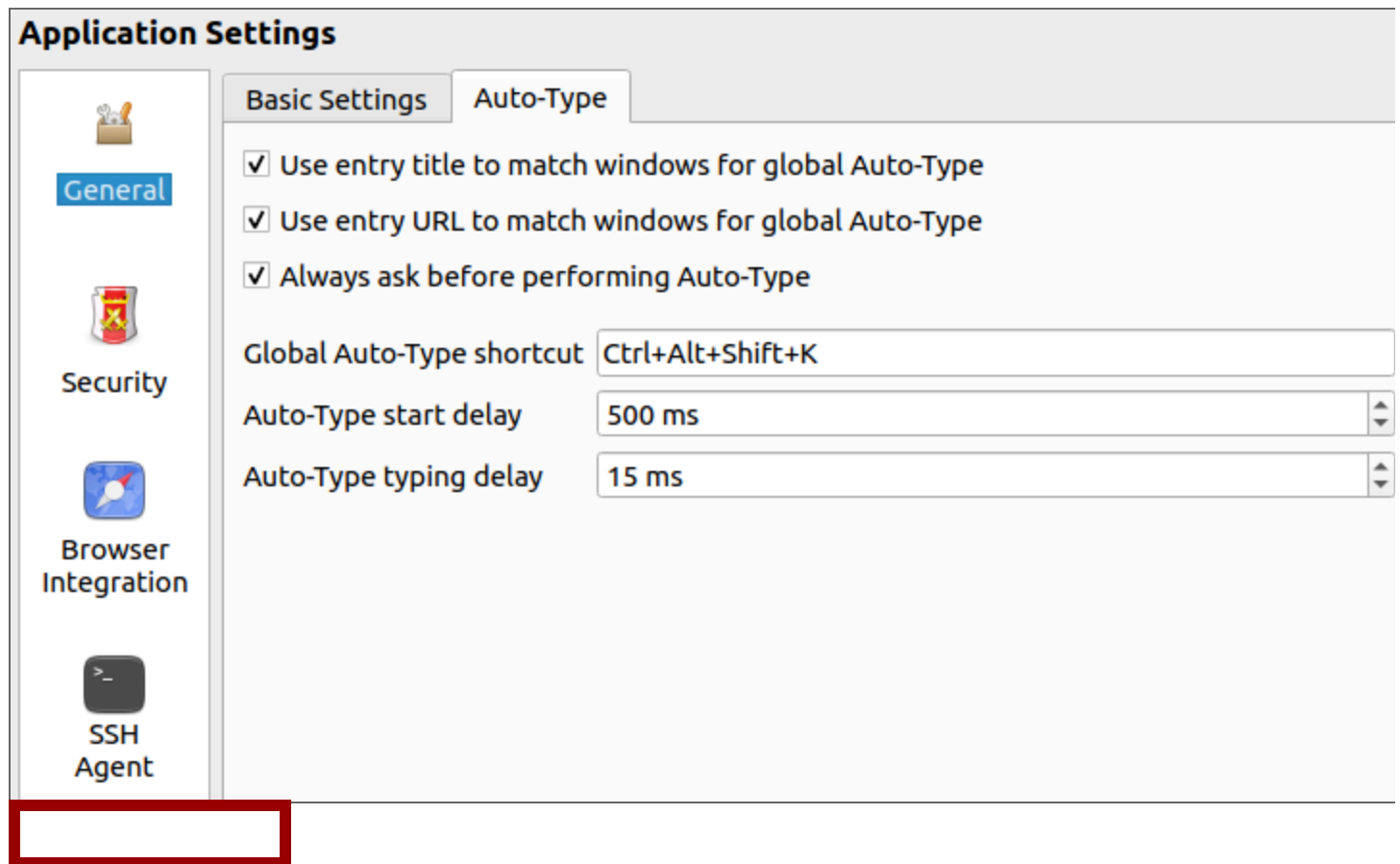
CTRL+SHIFT+V

Autotype

Tecle de atalho global

Autotype

Tecle de atalho global



eMail > primary > Edit entry



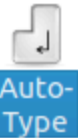
Entry



Advanced



Icon



Auto-Type

☒ Enable Auto-Type for this entry

☐ Inherit default Auto-Type sequence from the group

☒ Use custom Auto-Type sequence:

`{USERNAME}{ENTER}{DELAY 3000}{PASSWORD}{ENTER}{DELAY 5000}{TOTP}{ENTER}`

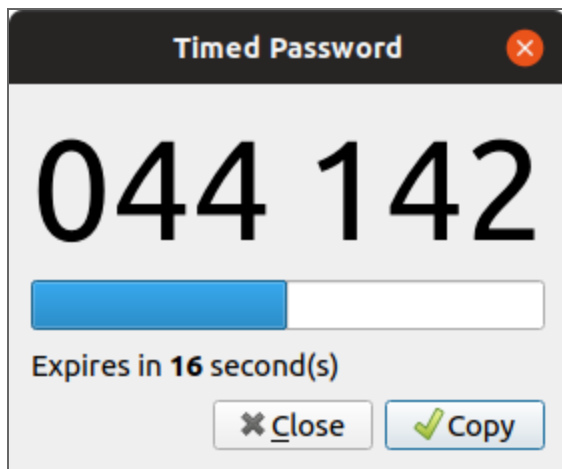
Window Associations

Window title:

☐ Use a specific seq

Autotype
Sequência configurável

TOTP



Integrando com navegador

Application Settings


General


Security


Browser Integration


SSH Agent

☒ Enable KeepassXC browser integration

GeneralAdvanced

KeePassXC-Browser is needed for the browser integration to work. Download it for [Firefox](#) and [Google Chrome / Chromium / Vivaldi](#).

Enable integration for these browsers:

☐ Google Chrome	☒ Firefox	☐ Tor Browser
☐ Chromium	☐ Vivaldi	

☒ Request to unlock the database if it is locked

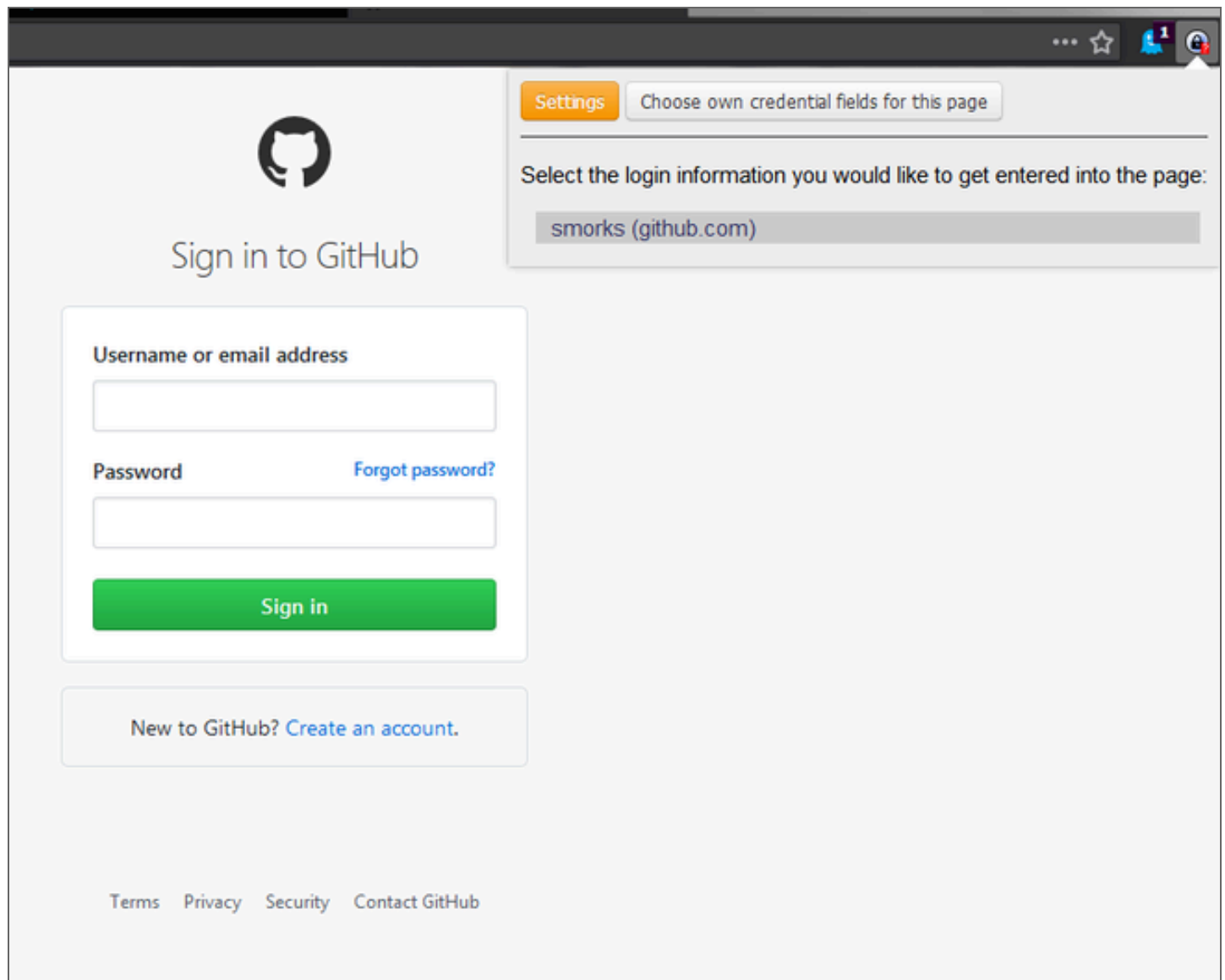
☐ Match URL scheme (e.g., https://...)

☐ Return only best-matching credentials

☒ Sort matching credentials by title

☐ Sort matching credentials by username

Integrando com navegador



The image shows a web browser window displaying the GitHub login page. The page has a light gray background. At the top left is the GitHub logo (Octocat) and the text "Sign in to GitHub". Below this is a white box containing the login form. The form has two input fields: "Username or email address" and "Password". Below the password field is a green "Sign in" button. To the right of the password field is a link "Forgot password?". Below the login form is a link "New to GitHub? Create an account." At the bottom of the page are links for "Terms", "Privacy", "Security", and "Contact GitHub".

On the right side of the browser window, a browser extension is active. It has a "Settings" button and a text field "Choose own credential fields for this page". Below this, it says "Select the login information you would like to get entered into the page:". There is a dropdown menu showing "smorks (github.com)".

Integrando com navegador

Nas configurações do navegador:

- Desabilitar autocomplete
- Desabilitar de salvar senhas

ssh-agent

Raíz > Add entry


Entry


Advanced

Title:

Username:

Password:

Repeat:

URL:

☐ Expires

☒ Notes

1 - Criar uma senha para a chave privada e copiar

ssh-agent

2 - Gerar uma chave SSH com a senha copiada

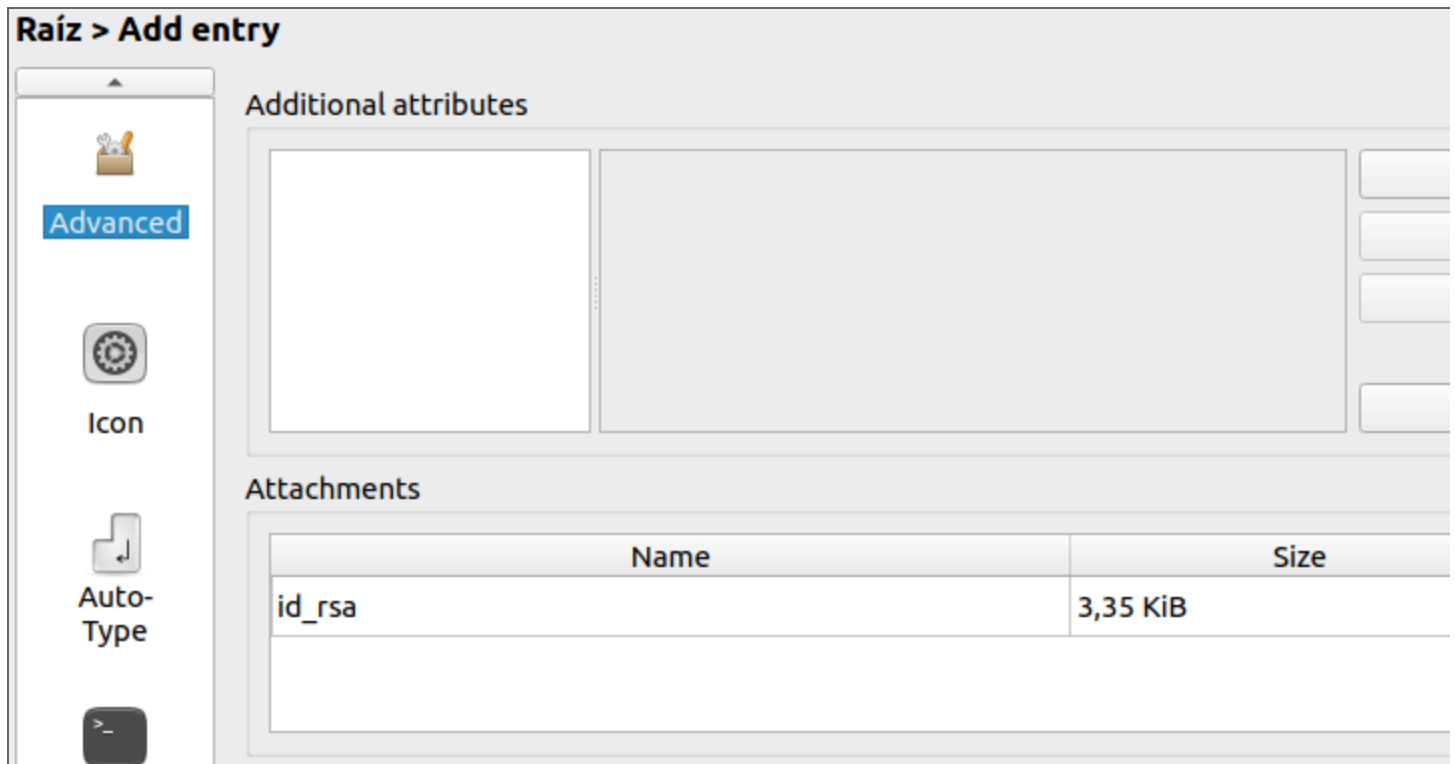
```

~$ ssh-keygen -t rsa -b 4096 -o -f id_rsa -C user@email.com
Generating public/private rsa key pair.
Enter passphrase (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in id_rsa.
Your public key has been saved in id_rsa.pub.
The key fingerprint is:
SHA256:/0AquhdSloVxKketevMFRknU+UgniQI4OxWzZOv2HHg user@email.com
The key's randomart image is:
+---[RSA 4096]----+
|  .*00*++ o      |
| 00.=00* * .     |
| ++ 0* . =       |
| 0. += 0 . .     |
| .++E.S..        |
| .o++ . +.       |
|  o++..o         |
| .... 0          |
| 00 .            |
+----[SHA256]-----+

```

ssh-agent

2 - Anexar o arquivo id_rsa no KeePass



ssh-agent

3 - Informar onde está a chave privada e utilizar a pública

Advanced

Icon

Auto-Type

SSH Agent

☒ Add key to agent when database is opened/unlocked

☒ Remove key from agent when database is closed/locked

☐ Require user confirmation when this key is used

☐ Remove key from agent after 600 seconds

Private key

☒ Attachment id_rsa

☐ External file

Add to agent Remove from agent

Fingerprint MD5:37:8d:c4:83:30:12:30:1e:63:14:c5:a8:15:e3:90:a0
SHA256:6hKPtN8/Kb9ZUz12rRwevxHf2qdvJ8x4b6fB3fS2o0k

Comment user@email.com

Public key ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQCE3A47E1HbDUcjN6XdERukLWxh4
RtZ+K8YUsjzyPbheAjFr2b6cF3Z5BIRYu9U753LYQXTsAR8gvS3meqs18
ScCaSr7aKQEkSDkaSM0m4B1ho71cRSY1Sh+2m+3aF0uLorpbh1B7ig8v9

Copy to clipboard

ssh-agent

3 - Informar onde está a chave privada e utilizar a pública

```
~$ ssh-add -l
4096 SHA256:6hKPtN8/Kb9ZUz12rRwevxHf2qdvJ8x4b6fB3fS2oOk user@email.com (RSA)
~$ git clone git@github.com:vitormattos/crack-password-calc.git
Cloning into 'crack-password-calc'...
remote: Enumerating objects: 67, done.
remote: Counting objects: 100% (67/67), done.
remote: Compressing objects: 100% (56/56), done.
remote: Total 67 (delta 23), reused 0 (delta 0), pack-reused 0
Receiving objects: 100% (67/67), 26.59 KiB | 41.00 KiB/s, done.
Resolving deltas: 100% (23/23), done.
```

Temas

https://wiki.archlinux.org/index.php/qt#Configuration_of_Qt5_apps_under_environments_other_than_KDE_Plasma

1 - Instalar o qt5ct

```
sudo apt install qt5ct
```

2 - Exportar a seguinte variável:

OBS: pode colocar no arquivo ~/.profile

```
export QT_QPA_PLATFORMTHEME="qt
```

3 - Execute o programa qt5ct e escolha um tema

PHP

Packagist *The PHP Package Repository*



Packagist is the main Composer repository. It aggregates public PHP packages Installable

keepassphp/keepassphp KeePass password manager in PHP	PHP
xp-forge/keepass KeePass databases	PHP
pbergman/keepass a keepass lib for php	PHP
keepassphp/keepassphp-ui User interface for KeePassPHP	PHP

Referências

<https://keepassxc.org/>

<https://keepass.info/>

<https://wpengine.com/unmasked/>

https://en.wikipedia.org/wiki/List_of_data_breaches

<https://github.com/hashcat/hashcat>

https://php.net/password_hash

The life





Obrigado!

Podem fazer perguntas durante
o evento

Redes sociais:

(VitorMattos ou VitorMattosRJ)

